



AI前沿：IT交付与人工监督的交汇点

当建筑软件的价格下降时，优势将转向确切知道要构建什么、在哪里实施治理以及如何管理代理型员工。

OLIVER WYMAN
A MARSH BUSINESS

内容

引言——瓶颈随工作流程向下游转移	3
1. 要求与意图——当代码免费时，价值去向何方？	6
2. 工程——构建可靠的工程运行模型 18	
3. 配送与运营——代理人能否安全地发货和操作软件？	28

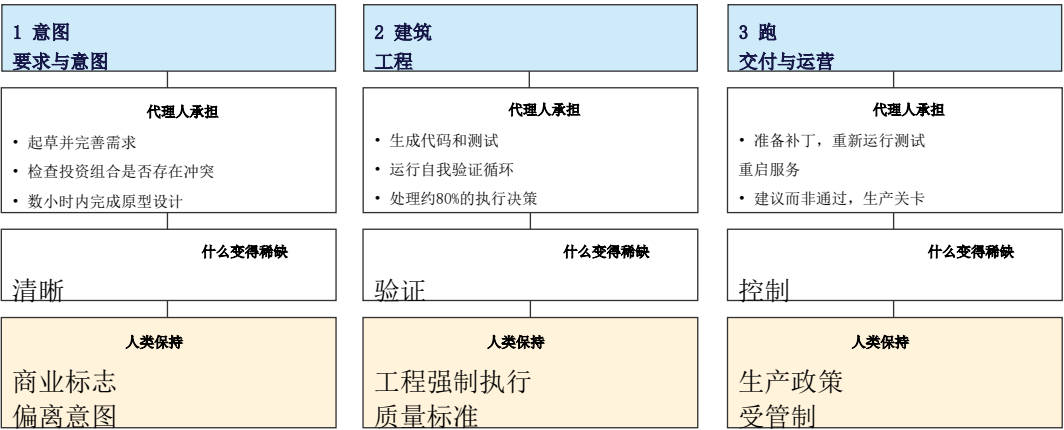
引言

代理式人工智能降低了编程成本，但这并不意味着软件开发变得廉价。

部署自主型人工智能并不会缩短交付链条，而是重塑它。企业必须更清晰、更迅速地决定其需求；工程部门必须在不降低质量的前提下验证更大量的产出；运营部门必须识别代理在生产中可能采取的行动以及相应的控制措施。本文探讨了这三个要点。

图1：瓶颈随工作流程向下转移——清晰度，继而验证，再而控制

工作向下流动——瓶颈随之移动



自主性源于可验证性。衡量从意图到生产有多少优质工作得以留存。

源自奥利弗·怀曼分析（示意图）。按工作流程顺序从左到右阅读；本文件每一章代表一个阶段。

瓶颈随着工作流程向下游移动而转移。

多年来，软件交付一直围绕 workflow 链条中间的稀缺资源进行组织。工程能力是瓶颈。现在情况已经改变。智能代理（Agentic AI）意味着代码可以更快地产生，但这并不意味着整个链条平行加速。相反，压力向上游转移至意图的清晰度，而工作则向下游转移至验证、发布和运营控制。接下来的三章按照工作流的顺序排列，反映了每个章节为下一个章节创造条件的现实。

在编写一行代码之前就开始。当产出第一章——需求与意图时，一个模糊的简报会变得更加昂贵。风险在于，现在可能会快速构建出错误的东西。我们主张将需求视为一组受管理的资产，这些资产清晰、可测试、有版本控制，并在团队间进行协调，同时将最终决策权留给业务方。实际问题在于，组织能否足够清晰地陈述其需求，并足够快速地做出决策，以便代理能够行动。

它关注的是构建本身。这正是代理式AI最显著的地方，也是最容易将更多输出与更多价值混淆的地方。随着生成的加速，审查、测试和领域判断的过程成为瓶颈。因此，本章将注意力从代码量转移到可验证性上。这意味着要给代理分配可以可靠检查的工作，使质量门禁持续且难以绕过，并衡量实际通过管道的是什麼，而不是产生了多少代码。

促进最终步骤进入生产。在此，第3章——交付与运营的问题不再是一个代理能否行动，而是它应该被赋予何种权限。本章划定了实际的操作边界。根据交付系统，领导者可以将本地、可逆的数据平面操作（如准备补丁、重新运行测试或重启服务）委托给人工智能。同时，他们可以要求人类监督生产策略、审批关卡和其他控制平面的决策。这只有在平台使每个操作都可见、可追溯且可逆时才有效。

哪三章节相互关联？

加速生成减少了约束条件。瓶颈虽然转移了但并未消失，反而暴露了下一个瓶颈。同时，也移除了一个先前免费运作的过滤器。当建筑成本高昂时，成本因素禁止了低价值功能的创建。现在成本降低了，必须将限制设计在内。如果这样不做，软件将变得更加复杂，运行成本更高，使用难度也更大。在新模式下，稀缺资源变成了上游的清晰度、中游的验证以及下游的控制。投资应随之转移。

同样的原则适用于每个阶段，因此自主性应遵循可验证性。业务部门确认意图，工程部门执行质量标准，而人类团队管理生产政策。代理人在其工作能够被快速检查和安全撤销的地方应被赋予更多自由，但并非仅仅在其技术上能够行动的地方。

代码量、工具采用和感知速度都是衡量价值的弱代理指标。关键在于衡量从意图到生产的有效成果，并确保其质量和稳定性。此外，软件到达后必须得到实际使用。当务之急是监控这一流程，并让证据决定推广的节奏。

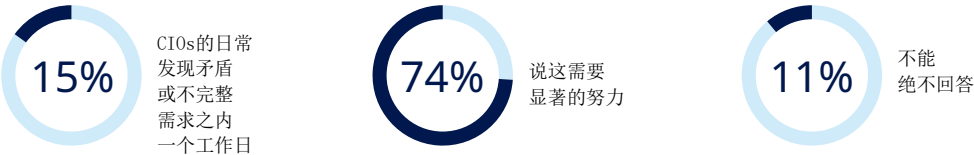
如何阅读此文档

初次阅读时，我们建议按顺序阅读这三章。这样做是有道理的，因为需求创造了需要工程验证的规范，而工程则创造了交付必须发布且安全运行的变化。之后，每一章都独立存在，作为决策指南。它们共同回答了一个CIO的问题：当代理使生产加速时，工作流程中必须做出哪些改变，才能让速度带来可靠的软件，而不是更快的返工和风险？

图2：瓶颈向下移动，数据解读

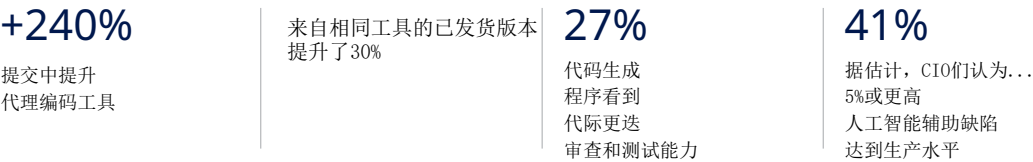
第一章 — 要求与目的

您能否清晰地说出您的需求，并迅速做出决定，以便代理人能够行动？



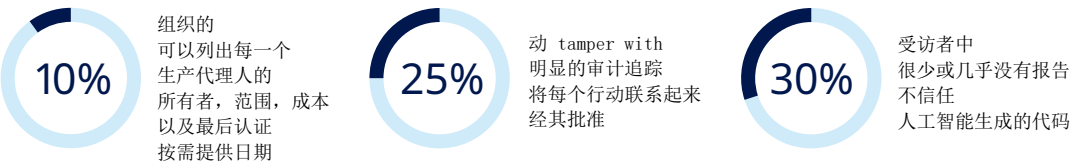
第二章 — 工程

提交到生产部署的整个过程中，生产力的提升是否能够保持？



第三章 — 配送与运营

代理人能否安全地运输和操作软件，以及您能否重建他们所做事情？



奥利弗·怀特曼2026年CEO与技术领袖平行调查（关于代理式AI与IT），2026年7月；德米尔尔、穆索夫与杨（麻省理工学院斯隆管理学院），2026年，关于承诺发布提升的部分；DORA，《2025年AI辅助软件开发状态报告》，关于对AI生成代码的信任。数据来自第1至3章呈现的图表。

要求与意图

代码免费时，价值去向何方？

1

意图要求与意图
稀缺：清晰

2

构建工程稀缺：验证

3

RUN

交付与运营 稀缺
：控制

当做错误的事情既快又便宜时，明确自己需要什么就成了稀缺资源。

需求与意图：当代码免费时，价值去向何方？

发生了什么变化？

人工智能让编写可用软件变得容易多了。然而，仍然困难的是决定要构建什么——并且要精确且快速地完成，以保持代理的运作。虽然代码曾经是瓶颈，但现在这种稀缺性已经转向了清晰、一致的简报，以及能够快速做出决策以采取行动的高层支持。在大型公司里，这种情况只会变得更难，因为不同团队越来越多地使用人工智能参与草拟过程，此时可能会同时收到数百个请求。这些请求不能相互矛盾，并且每个请求都必须足够完整，以防止人工智能快速构建出错误的东西。撰写一份好的简报曾经是一门手艺。现在，它必须像管理一个活生生的产品一样进行管理。

附件3：通过代理，交接过程被压缩，周期时间得以回收

在代理之前：每个阶段都以人类速度运行



代理之后：以代理速度构建运行



决定要
做就
更重要

很大程度上

代理测试是构建：变成
自动化但
商务接受自动化
变得关键路径

核心交付步骤

交接步骤

来源：Anthropic，《AI原生SDLC手册》，2026年8月

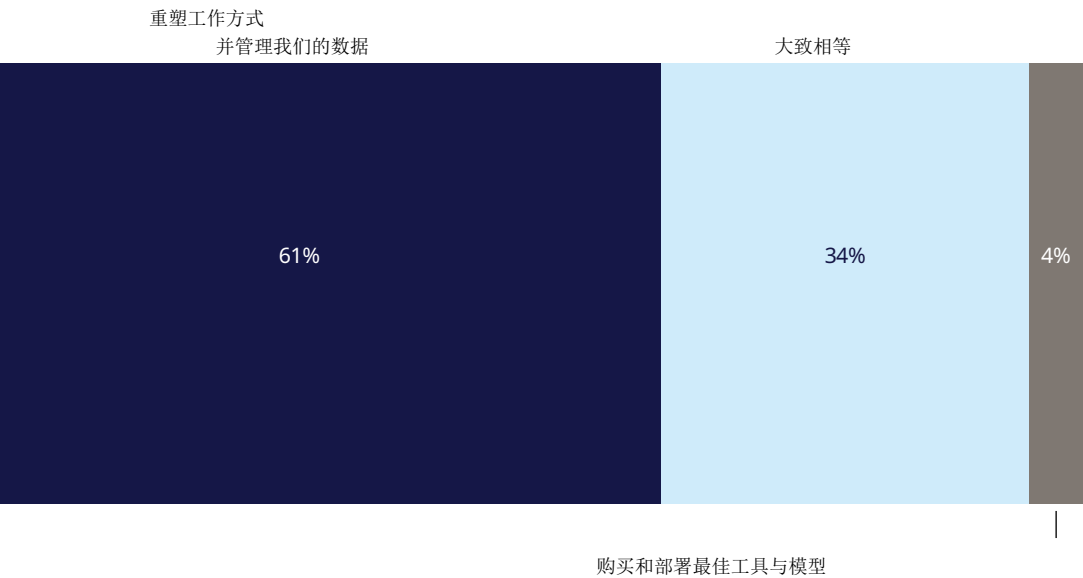
我们的观点

企业必须将实际投资用于运用人工智能和合适的工具，以确保需求理解准确无误，而不仅仅是更快地生成代码。将需求视为一个包含版本历史的“活”的真相来源：跨功能更新需求、协调矛盾，并记录关键决策的制定过程。与业务部门保持最终确认，并重建业务与IT围绕频繁、良好决策协同工作的方式。人工智能所能提供的价值越来越取决于企业能否明确其需求并迅速做出必要决策。更快的代码生成并不能解决模糊或冲突的需求。

我们对这个方向充满信心：约束已从构建软件转变为决定要构建什么。我们对工具本身则更为谨慎。学术研究表明，软件现在可以自动检查需求中的矛盾，但用于管理需求（或简报）的端到端工具仍处于萌芽阶段，目前还没有针对需求是否契合项目总体目标的大规模、独立评估方法。

图4：CEO们认为工作流程再造的收益不在于工具，而在于流程本身

CEO们认为代理式AI的主要收益来源是哪里，%的受访者



奥利弗·惠悦 2026 年 CEO 与科技领袖代理型 AI 与 IT 并行调研，2026 年 7 月

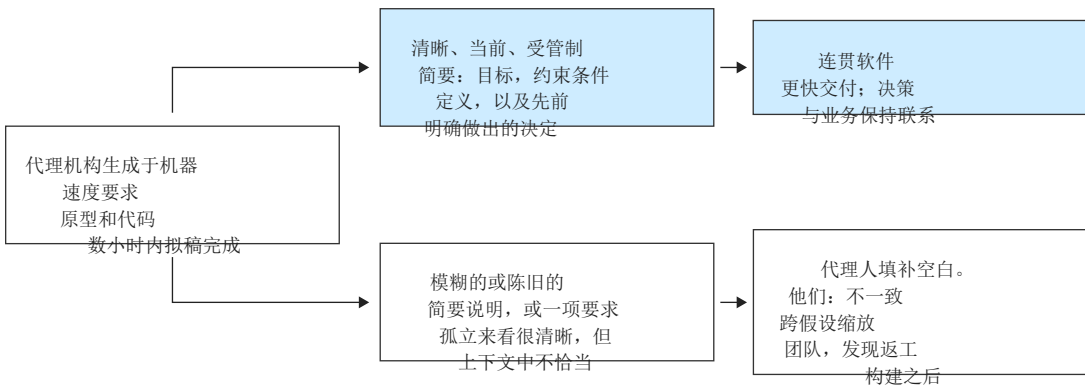
1 A. Veizaga, S. Y. Shin和L. C. Briand, “自然语言需求中的自动化气味检测与推荐”，IEEE软件工程汇刊第50卷第4期，2024年，第695 - 720页

请要求您的团队识别出哪些现行要求相互矛盾，哪些不完整。在我们的针对130名受访者的CIO调查中，只有15%的人表示他们的组织能在一天工作时间内常规性地回答该问题。另外74%的人表示这需要大量努力，而11%的人完全无法回答。如果您的组织无法快速提供可靠的答案，则在允许AI大规模构建之前，请先解决该能力问题。

当决策跟不上编码时会发生什么？

人工智能的代码生成能力正以大型组织难以协调需求并做出决策的速度在增长。五个挑战将瓶颈问题提前了。前两个挑战关乎意图的质量和一致性。接下来的两个挑战涉及权限、治理和决策速度。第五个挑战则关乎决定不构建什么的纪律。

图5：廉价代码放大其被赋予的简报



编码速度更快并不意味着决策速度更快：签核流程仍由业务部门负责，因此决策速度成为瓶颈。

奥利弗·怀特曼分析（示意图）。第一章阐述了推动瓶颈上游化的五大挑战。

1. 代理机构可以调整不一致的假设

人工智能几小时就能草拟需求和原型，但它无法领会人们通过会议、经验和日常协作所建立的真实世界、非正式的背景。此外，应用程序的文档可能过时，无论是编写规范还是代码本身。

如果目标、约束、依赖关系、数据定义和先前决策没有被明确说明或保持更新，代理将自行填补这些空白。否则，下游的不同团队和代理可能会做出不同的假设，从而产生大量看似合理但既无法整合也未能反映预期结果的代码。

员工仍然可以使用人工智能来更快地起草需求，但在建设开始之前，他们还应该使用它来提出、丰富和测试这些需求的潜在影响。

2. 一个要求在脱离语境时可能很清晰，但在语境中却可能是错误的。

一项要求单独阅读时清晰，但在引入整个组织时仍可能失败——因为它可能与现有的数据模型、系统、流程、政策、法规或其他正在进行中的变更产生冲突。现在，软件可以一次性检查整个产品组合中要求之间的矛盾；独立的学术测试表明，人工智能可以可靠地标记不完整或模糊的要求，而早期研究将此扩展到冲突或相互依赖的要求。² 这解决了人工审核在规模化处理时难以应对的问题，但前提是公司首先就人工智能进行检查的通用定义达成一致。

但检测矛盾相对容易。更困难的一步，正如受控研究所示，是在编写任何代码之前，将每项要求与现有系统、规则和依赖关系进行核对。这样做可以在错误蔓延之前发现它们。³ 但尽管自动化检查可能能够证明软件符合需求说明，但它们无法证明该需求说明是否表达了业务的需求或期望。

3. 编程速度更快并不一定意味着决策速度更快。人类仍然需要对需求进行确认。

人工智能或许能够组织并起草需求，但判断他们所起草的内容是否正确——并正式批准——这不是可以委托的事情。这项责任始终属于企业，因为最终企业要对结果负责。⁴ 任何由此产生的延误都会增加成本：代理人要么等待，从而降低对其投资的回报，要么基于其自我生成的假设继续工作。这会导致偏差，并在后期制造更多工作。

4. 简要质量成为成功执行的关键瓶颈。

通常情况下，需求说明（briefs）没有得到妥善管理：可能没有版本历史记录，或者没有可从中生成软件的主源文件（这与其说是关于代理（agent）被授予的自主权水平的问题，不如说是关于规格作为产品（spec-as-product）成熟度的问题）。

然而，今后必须确保简报保持完整和一致，并且业务决策得到相应体现。公司自动化规模越大，简报就越需要规范性——只有当生成工具成熟并被信赖时，全面实施才能获得回报。⁵ 如果成功做到这一点，那么需求管理将停止制造更多文书工作，转而成为对一项宝贵资产的管理。

² I. 达里夫 (Darif), 尼乌 (F. Niu), 阿布拉蒂夫 (M. Abdellatif), 布里亚德 (L. C. Briand), 拉梅什 (S. Ramesh) 和 阿迪斯南 (A. Adiththan), “利用大型语言模型自动检测需求依赖”, 2026年2月。

该工具正分裂为两大阵营。成熟的规范平台如Jama Connect侧重于受控规范、可追溯性和受监管环境，而新的规范驱动型工具——如AWS Kiro、GitHub Spec Kit和BMAD-METHOD——则更直接地利用规范来协调AI辅助开发。该类软件仍在发展演进中，因此CIO们应通过具体用例进行试点，而非过早地将其中任何一种作为标准采用：合适的工具取决于该简报主要是受控记录，还是协调跨交付代理的操作性输入。

5. 低价代码移除了过去曾用于阻止低价值工作的过滤器。

当建筑成本高昂时，成本充当了一个粗略但有效的过滤器：那些无法证明值得团队投入时间的功能永远不会被开发。随着生成一个功能的外边际成本趋近于零，这个过滤器就消失了。风险并非开发者闲置，而是相反：大量功能被开发出来，仅仅因为它们“可以被”开发，而非因为任何人需要它们。每一个发布的功能都带来了生成成本无法削减的成本。它必须被测试、保障、文档化、集成，并在产品存在期间得到维护，同时它还要与那些重要的功能争夺用户的注意力。

结果是，软件变得越来越复杂，运行成本越来越高，同时使用难度也越来越大。防止这种情况需要的是需求端的规范，而非工程端的：每个请求在进入简报前必须达到明确的价值门槛；能显示哪些功能实际被采用的使用数据；以及拥有否决权和权限淘汰不再被使用的功能的指定负责人。如果一个组织无法阐明某个功能为何存在，就不应该因为相关人员有能力就允许他们去构建它。

6 Anthropic, 《AI原生SDLC手册》，2026年8月。

图6：资金和注意力应投向何方

From	To
将简报视为一份可丢弃的文件， 移交工程师后即过时	管理需求、简报 并且，那些决策被视为有生命的、可追溯的资产
依赖他人来捕捉所有矛盾 手工	自动检查跨需求 冲突项目
按月或按季审批 阻碍能动性收益。	赋能业务与产品负责人 批准决策并在其中解决权衡取舍问题 一周，或者最好是有一天
将那些粗糙的原型作为成品寄送 产品	快速、一次性使用的基于氛围编码的原型 测试用户想要什么
针对重点问题进行修复以展示进展。 不后退考虑从开始 白板	梳理端到端流程、决策 在构建之前，考虑例外情况和预期结果。
允许代理人和工程师填补空白。 未经验证的假设	记录假设、约束和 未决事项作为简报的一部分，因此 代理人不会做出不一致的假设。
构建每一个请求，因为生成 使其廉价	每个请求都必须超越的值阈值 它进入简报中关于功能使用的数据 被采纳，以及一个有明确所有者 拒绝请求并退役功能

奥利弗·怀曼分析。

明确核心定义

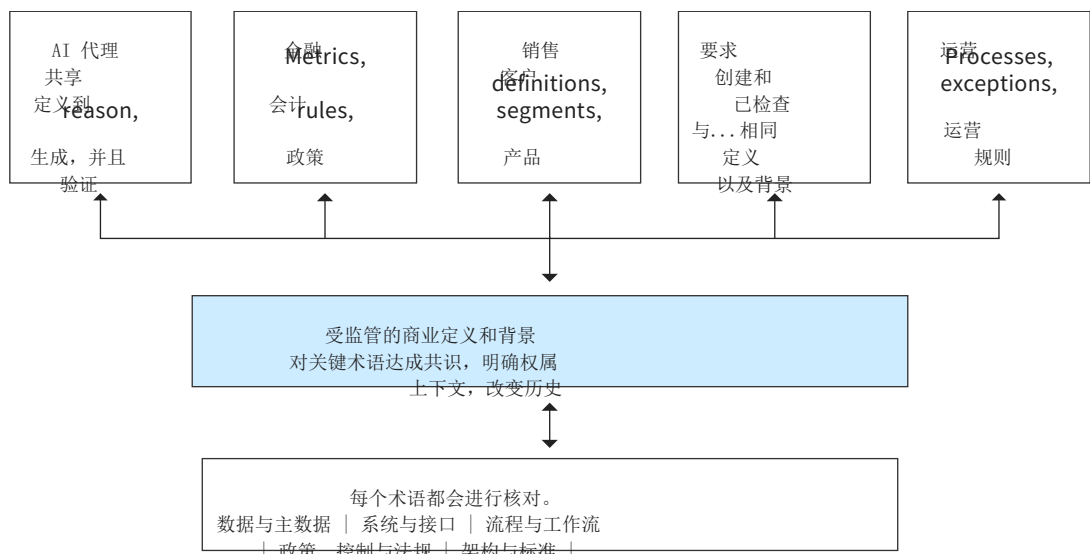
许多跨团队冲突源于对术语的不同理解。“客户”、“活跃账户”、“收入”，甚至“完成”这些词在财务、销售和运营部门中各自可能包含三四种定义。在人员和代理能够基于相同要求工作时之前，组织需要为其核心业务概念建立共同的语言。这意味着不仅要就相关术语的含义达成一致，还要就它们在数据中的表示方式达成一致：标识符、字段、关系和规则。但尽管人们通常可以通过对话和经验弥合此类不一致性；代理却做不到。如果名称、定义和数据结构不同，代理可能会每次对相同的请求做出不同的解读。

图7展示了标准方法：将约定的条款、数据结构及其含义的上下文统一存放在受控位置，然后为每个需求和代理使用该参照。单一的、企业范围的定义并非总是适用，因此批准的变体应说明其适用范围。在此，所有权、版本历史和变更控制至关重要，因为更改一个定义或数据结构可能同时影响多个需求和代理行为，产生连锁反应。

直到这些定义被同意并集中管理——技术人员称之为“共享语义层”——每个团队，以及现在每个AI代理，都基于自己的版本进行工作。不同的团队只有在模块无法契合时才会注意到矛盾。

因此，他们应从小的范围开始，先就最重要的少数几个术语达成一致，将这些术语集中管理，并以此作为所有需求和代理人的参考依据。正是这种治理机制使得自动冲突检查成为可能，因为软件只有在每个术语都有一个可供对照的受控定义时才能标记出冲突：要么尽可能采用单一的企业释义，要么是一套明确的、具有清晰适用规则的、特定于上下文的释义集。这种工作无法现成购买，因此需要投入工作。它可能会挖出先前隐藏在格式不匹配的电子表格中的开放性定义争议，但它将是所有其他工作的基础。

附件7：关于人员、要求和代理人的统一定义



治理至关重要：明确的负责人、变更审批以及审计历史记录是保持各层级可信的关键。

为什么这很重要

单一事实来源 集中管理关键业务术语及其定义。 自动冲突检测：需求和代理人都根据相同的定义和上下文进行检查。 企业范围内的统一性——无论人类还是人工智能，都基于同一含义进行工作。 变更受控，所有权与变更历史确保定义演进而不破坏一致性。

同意关键条款并将其集中管理，有助于治理，并能实现自动跨项目冲突检查。

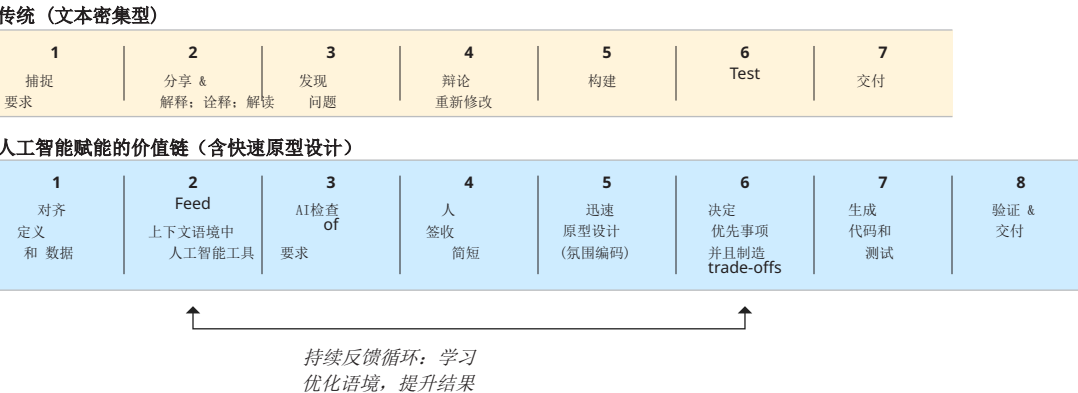
管理冲突目标

一旦基础定义达成一致并确立，接下来的、更复杂的挑战就是解决优先级冲突。利益相关者可能对事实达成一致，但仍希望有不同的

结果，但共享的定义和评分模型仍然无法解决相互冲突的激励。相反，这需要指定领域所有者、由高级管理人员进行仲裁以及在建设开始前的战略选择。如果没有指定负责人，工作就会停滞不前，或者嗓门最大者获胜。这两种结果都无法证明战略的存在。

人工智能驱动的快速原型设计，通常被称为“氛围编码”，提供了一种更快地集中优先级的方法。团队无需在冗长、文字繁多的规范中就竞争性需求进行争论，而是可以将流程知识、数据、规则、约束和假设输入到智能体中，并在数小时内将不同选项转化为原型。通过与用户和业务负责人快速测试这些选项，可以迅速发现优先级冲突之处，并使权衡取舍变得具体化：哪些有效，哪些无效，以及业务愿意放弃什么。然后，通过短反馈循环，将选定选项转化为包含明确用例、验收标准和测试用例的更丰富的规范。一旦达成一致，后续的代码生成就变得更加自动化，也更容易验证。

图8：人工智能如何改变从商业意图到可工作软件的路径



使其运作的控制装置

- 一人所有，一份权威版本
- 设定决策权责与响应时间
- 代理行动前进行验证（人工确认）
- 监控偏差并重新验证

源自奥利弗·惠悦分析。人工智能赋能的软件交付价值链示意图。

在一家最近的金融服务客户那里，一个代理式 workflow 原型在两天内就准备好了，但部署被推迟了十周，因为首席运营官办公室、IT部门和财务部门就应快速推出一个范围狭窄的解决方案，还是等到生产集成、控制所有权和效益案例都完全达成一致后再启动争论不休。客户发现打破那僵局的最佳方法是在首席运营官办公室任命一位高级赞助人作为

责任决策者，并引入一个由一页决策备忘录和五个工作日响应目标支持的每周决策论坛。通过采取这些措施，客户能够将后续审批周期从周缩短至天。

执行准备能力测试

CIO无法单独解决决策速度问题。有五个问题可以告诉任何高管，组织是否已做好准备：

1. 哪些主动需求存在冲突或不完整，我们能在一天内查明吗？
2. 当业务领域希望达成不同结果时，由谁打破僵局？

如果那些答案缺失了，那么再投资代码生成工具也无法解决瓶颈问题。

将简报视为关键资产进行管理

随着代码生成变得商品化，持久性的优势正转向那些能够比竞争对手更快地将意图转化为可靠、可运行的软件的公司。然而，变得稀缺的是：撰写一份完整、无冲突且指定了负责人（named owner）的需求文档（brief）的能力；在一天内就能知道该文档是否包含不一致或遗漏；以及在交付的节奏下，成功促使领导层做出决策。

建立和保护知识产权需要围绕塑造它们的领导决策建立运营控制机制。将简报视为一个共享数据库，而不是一个文档文件夹。它应有明确的归属、一个权威版本、可追溯的决策、代理人行动前的核查，以及对重大决策设定响应时间。

鉴于这将影响多少决策，需要采用分层渐进的方法：可逆、低影响的选项应与AI的工作节奏保持一致；跨领域的权衡、受监管的决策和不可逆转的承诺则应遵循更审慎的节奏——每种情况都应明确响应时间预期，以便将速度设计到流程中，而不是偶然发生。这样一来，决策延迟就可以成为另一个可量化的性能目标。

图9：适用于行动摘要的四项控制措施

控制	最低运行标准
一位主人 权威的 版本	一位有姓名的商家对这份简报负责。每一次变更都可追溯。 一个人、权威、理由以及先前版本。副本被链接、同步或 retired.
验证前 代理人行动（人类） （人工智能辅助）签收	检查需求的完整性、冲突定义、流程和系统 生成前的依赖项、策略约束以及可测试的验收标准 开始。确认每个请求都达到了明确的值阈值；生成正在 便宜不是建设的理由。
设定决策权 以及响应时间	代理人可在既定框架内处理可逆的、低影响的选择。材料， 受监管、跨域且不可逆的选择会分配给明确的指定所有者。 响应时间目标
监控漂移和 重新验证	注意系统、政策、定义、流程或优先事项何时发生变化。 材料变更将触发重新认证，并在需要时更新营业执照。 批准。跟踪哪些已发货的功能实际上被使用，并告知所有者。 撤销不合理的权力

来源：奥利弗·怀曼分析。这些控制结合了“像管理资产一样管理”的原则，以及对保持审批人为化并在人工智能行动前进行检查的独立研究。漂移信号旨在跟踪您自己的工作，而不是作为已证实的行业基准；目前仍然没有衡量需求完整性的大规模标准。

掌握自己想要什么的组织将占据优势。

随着代码生成日益商品化，不久的将来，每个竞争对手都将运行基于相似模型的可比代理。差异将取决于那些代理被要求构建什么。我们的建议依然不变：在扩大生成规模之前，先投资于前期规划，并且对于不构建什么要像对于构建什么一样审慎。然后实施受控定义、具有命名所有者的单一权威版本、代理行动前的检查，以及与风险和可逆性相匹配的决策权。这些要素都无法购买；它们代表了业务和IT共同决策方式的转变，其进展体现在决策所需时间的长短。

那些清楚自己想要什么并且能够决定其代理人员工作节奏的公司，将从人工智能中获取最大价值。那种花了两天时间制作的原型却等了十周才获批的模式，是企业现在就应该着手消除的类型，而自主交付（agentic delivery）的应用仍处于快速扩张阶段。否则，企业会发现，缓慢决策的成本会随着每一位新代理人员的加入而不断叠加。

交付与运营 稀缺：控制

更多代码并不等于更多软件。约束已从编写代码转变为验证发布后留存的内容。

构建可靠的工程运营模式

运营现实

自主AI在构建阶段最为明显，这也是其影响最常被夸大的地方。Anthropic对40万次Claude Code会话的研究发现，大部分收益是由领域能力而非AI本身带来的。⁷ 随着它们沿着交付链向下移动，收益也会减少：在提交代码方面的约+240%提升，在项目层面降至约+80%，而在实际发布的版本中仅为+30%。⁸ 因此，虽然编写代码正变得廉价，但将其转化为可靠且真正能交付的软件仍然很困难。对于CIO而言，当数量变得廉价时，问题在于应该将重点放在哪里，以便额外的产出能创造价值而非债务。

此观点聚焦于交付链的中间环节：软件是如何被构建和接受的。

代理工程

将代理系统导向可靠的产出。人类设定方向、护栏、要求和验收标准。代理负责执行、生成、测试、验证合规性并部署。

我们的观点

随着代码生产的成本降低，投资重心应从生成更多代码转向那些稀缺的资源：领域知识、确保产品发布后仍能存活的评审能力，以及实施无法绕过的质量门槛的能力。给予代理过多独立性可能导致代码一致性降低、IT债务增加，以及产品增长速度超过用户或维护者吸收能力：任何通过管道的功能仍需经过评审、保障和在其生命周期内持续维护。

企业应将可自动验证的工作交给代理，其余工作则保留给人员。不要因为依赖就等到最后才进行验证。

⁷ Hitzig、Massenkoff、Lyubich、Heller和McCrory，《代理编码与持续的专业技能回报》，Anthropic，2026年6月16日。⁸ Demirel、Mussolff和Yang，《编写代码与发布代码：跨代人工智能编码工具的生产力效应》，麻省理工学院斯隆研究论文（待发表），SSRN，2026年9月6日修订。

持续的警觉性——人们可能会感到疲劳，并且有可能过度信任疲惫的员工。相反，应将其作为一项贯穿整个建造过程的、工具支持的持续检查，纳入流程中。同时，要注重测量监控，以便能够量化实际进展速度，而不仅仅是估算。

单线比率：代码生成量与审查测试能力之比。

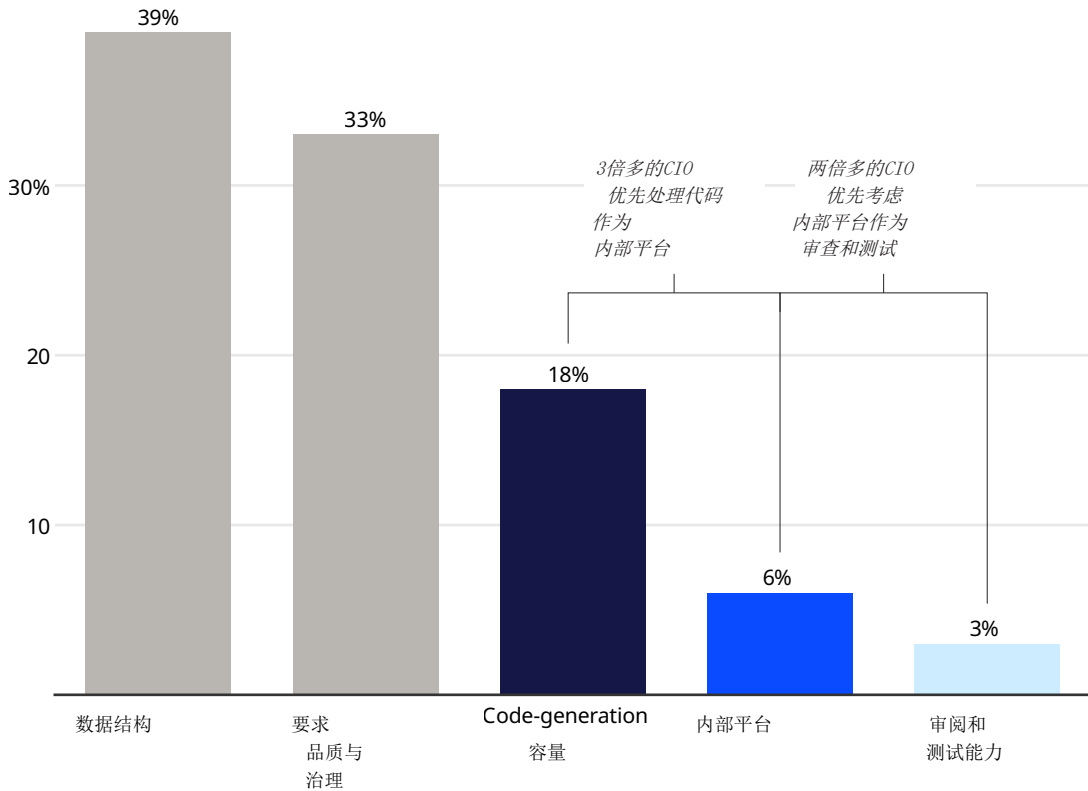
大约27%有代码生成项目的组织表示，代码生成速度超过了审查和测试能力，而41%的CIO估计，有5%或更多的AI辅助代码缺陷会流入生产环境。与此同时，审查和测试能力在过去一年中是五个投资领域中排名最后的。

如果代码生成量持续上升而相关控制保持不变，企业实质上就是在制造债务。在这种情况下，企业最好暂停代码生成的推广，重新平衡支出——将其投入到更多的审查和测试能力上——以避免处理量超出控制能力。

提交量增长了240%，但实际发布的版本增幅约为30%。生产力的提升是真实的——其中大部分并未成功发布到生产环境。

图10：代码生成能力仍优于可靠交付所需的平台和验证能力

过去12个月内，将每个领域列为其首要投资优先级的CIO所占份额，占受访者百分比

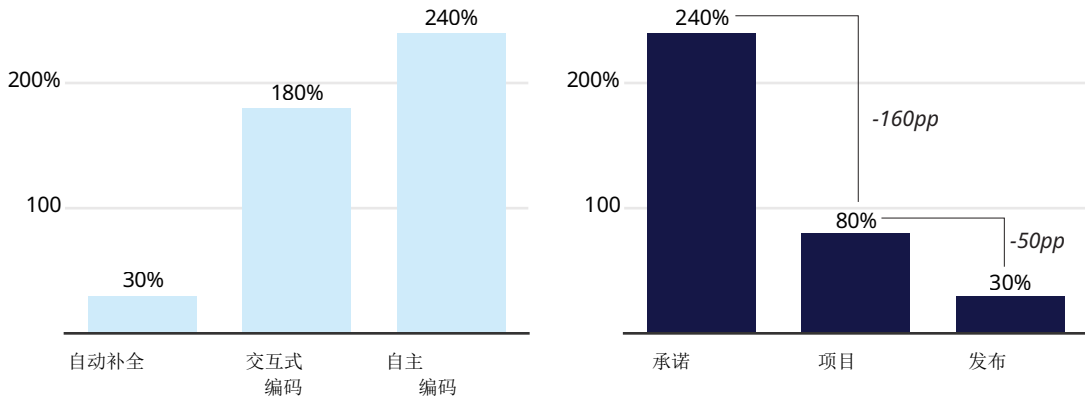


奥利弗·惠悦 2026 年 CEO 与科技领袖代理型 AI 与 IT 并行调研，2026 年 7 月

第11项证据：大量生产力提升在发布前就损失了

每一代工具的更新都使编码活动更进一步…… 各代工具对提交的累积影响

...但是，在产品交付之前，收益就会减弱。自主编码代理：在整个生产层级中的影响



迪米尔尔、穆斯奥夫和杨，“编写代码与发布代码：跨代人工智能编码工具的生产力效应”，麻省理工学院斯隆研究论文（待发表），SSRN，2026年9月6日修订。一项针对超过50万名GitHub开发者的配对事件研究的累积效应：两个子面板共享一个共同尺度。

第12项证据：将投资从发电转向验证和专业知识

From	To
“已发货的行数”或代码生成的座位数作为KPI	领域专业知识和审查能力
一项“给每个人配备一名代理人”的统一指令	基于可验证性的委托与上游 专项纪律
由人工编写的测试驱动的QA阶段	持续自动化验证：编码 完成定义，生成的测试，一项强制性 门，以及依赖项/软件物料清单门
传统的敏捷冲刺实践	围绕持续改进流程进行重组
为短期利益而削减入门级职位	保护上下级人才梯队建设

奥利弗·怀曼分析。

四个因素重塑了构建运营模式

第13项：四大因素重塑构建运营模式

当代际不再是限制时，会发生什么变化？

规划与执行分离

人类保留大多数计划决策，代理人
做出大多数执行决策。越清晰
越拆分，代理就能提供越多。

验证过程持续进行。

提交（的代码）数量超过了发布（的版本）数量。从...生成的测试。
规格、合成数据以及编码定义
完成循环门替换。

节奏从冲刺转变为流动

当一个小组几小时内发货，两周
冲刺失去了意义。高级产品架构师
保持持续的流动。

才能从知识转向技能

招聘与重训用于判断、复核和
代理人方向。组织设计与初级
管道成为首要决策。

来源： Oliver Wyman 分析。每个因素将在后续段落中阐述；人才计划将从CIO/CHRO的角度（C6）展开。

1

将规划与执行分离可以提高代理人的交付能力：在Claude Code会话中，目前人类大约做出70%的规划决策，而代理人处理大约80%的执行决策。⁹ 这种清晰的区分——即编码代理当前发挥优势的领域——表明，能够将规划与执行分离可以有效地、安全地带来生产力的提升。

⁹ Hitzig、Massenkoff、Lyubich、Heller和McCrory，《代理编码与持续的专业技能回报》，Anthropic，2026年6月16日。

2

实际上，这种分离能走多远取决于什么可以被验证。高容量、低复杂度的编码之所以便宜又快，正是因为它容易检查。有了合适的规范，代理可以生成一套强大的自动化测试，用于功能和非功能属性。对更复杂工作的验证越好，公司对最终产出的信心就越强。这反过来又支持给予代理更大的自主权，从而强化整个周期的效率。强大的验证也有助于弥补模型能力的参差不齐，否则可能会对不可靠的输出产生虚假的信心。

验证必须持续进行，而不是留到最后：如前所述，提交的数量远比发布快得多。如果没有相应的检查机制，这种额外的吞吐量可能会变成未来的清理工作和安全风险。大约有22.7%由人工智能引入的缺陷会存活到仓库的最新版本。¹¹ 在长期迭代任务中，代理编写的代码也会持续退化：在大多数运行中变得更混乱、更臃肿，并且生成的代码明显比人类维护的代码冗长。¹²

此外，风险不仅限于代理编写的代码。它们还会以机器速度导入依赖项，同时，Mythos级能力正使攻击者审计继承库以寻找可利用漏洞的成本更低。向疲惫的审查者工作负载中增加更多检查并不能快速解决问题；因此，验证必须与吞吐量同步扩展。¹³

因此，测试需要转变为一种持续的能力，涉及：基于规范的测试生成；合成测试数据；自愈脚本；以及一个编码化的“完成定义”，该定义能自动检查架构、合规性以及依赖项/SBOM。而测试人员则应将精力投入到质量策略上——基于风险而非编写模板来决定测试内容。最后，也或许最重要的是：问责制纪律需要保持至高无上，需要指定一名负责人来拥有价值提升带来的收益，以及承担成本/风险带来的代价。这个人反过来就成为了最重要的控制点，既受到激励又被赋权，以提供持续且一致的利益。

3

工作节奏将从冲刺转变为流动：既然一个小团队在几小时内就能完成过去一个大型团队需要数天才能完成的工作，那么两周的冲刺期相比以往来说就不再那么合理了。相反，高级产品架构师会组建团队（或称为“Pod”），而开发人员则将时间用于指导那些无需遵循固定时间表工作的代理。

¹⁰ 卡尔帕蒂/塞昆尼亚，2026年。¹¹ 《AI繁荣背后的债务》，2026年。

¹² 奥尔兰斯基等，《SlopCodeBench：基准测试编码代理在长期迭代任务中的退化情况》，2026年5月修订版。

4

知识之外，顶尖人才将带来需要经验积累才能掌握的技能：人工智能并非取代人类人才的需求。它正将招聘的重点从知识转向技能。这种模式并不新鲜：它曾随着转向更复杂编程语言和工具而出现。编码能力并非消失，而是改变了形态：清理未分配内存块的能力不再是差异化因素，而结构化问题解决、系统思维、基于抽象和封装的架构设计、勤奋以及沟通能力将继续保持重要，即使人类团队越来越多地监督代理并拥有代码的“完成定义”，而非亲自编写代码。超过三分之二的CIO表示，寻找和重新培训人才以利用代理是他们最大的人才限制，而只有3%的人提到“替换或减少工程师”。¹⁵ 但一个更难回答的问题是，当初级工程师无法像传统上那样接触基础知识以构建技能时，如何培训他们。答案是学徒制和特定代理的拥有权相结合，初级工程师向指定的导师辩护代理的工作，同时进行治理、风险管理、质量保证及相关主题的人工智能素养培训。留住优秀员工也变得日益关键。这意味着不仅要确保工程师掌握正确的技能，还要让他们从行政事务和琐事中解放出来，将时间用于高价值的问题解决。

简而言之：组织设计和初级人才梯队应是首要决策，而非人力资源的临时想法。

¹⁵ Oliver Wyman 2026 年 CEO 与科技领袖平行调研：关于自主人工智能与 IT，时间：2026 年 7 月

四种当生成超越控制时的失效模式

图14：代际更迭失控的四个警示信号

Risk	机制与缓解	残余的	所有者
无门限生成 产生债务	代码编写速度超过审查速度。 并测试能力。然后有更多代码 折叠进去，更多缺陷得以存活，以及那些 缺陷和安全风险会过后再次出现。 正在生产。功能也会随之发布。 它们可以建成，而不是因为 既然没人需要它们，所以代码库 增长速度快于用户或维护者 能够吸收。解决方法：不要让任何AI写的 代码合并直至通过自动化测试 测试与人工智能辅助审阅	HIGH	工程副总裁
验证器 退化	当模型为 MEDIUM - HIGH 时，人工审核质量会下降。 通常情况下是对的：评论者让 他们放松了警惕，因此出现了关键缺陷 在少数失败中隐藏，并且 结构不良的代码会不断累积。 隐形债务。修正：构建验证 （编码完成定义，生成） 以及属性/变异测试，并保持 审阅者亲自操作，以免他们的技能受到影响 atrophy.		工程副总裁
生产力 戏剧	团队推广人工智能是因为它感觉更快，MEDIUM 即使没有吞吐量基准 人工智能实际上可能会减慢专家的进度。 在成熟的代码上。钱随后被花掉。 在人工智能不增加净价值的地方，而 依赖 harness 的供应商基准 被误认为证据。修复：衡量 自行提高吞吐量和质量 管道：不要依赖调查或供应商 figures.		首席信息官 + 工程 领导力
Junior-pipeline 坍塌；崩溃；瓦解	代理人承担入门级工作，并负责初级职位。 招聘削减。三到五年内，由于 稀缺的投入，专业知识和技能并未得到补充。 而且缺乏中层人才来掌舵 代理人。保护管道和 刻意调整预期 人才发展实践	MEDIUM-HIGH	首席信息官 + 首席人力资源官

来源：奥利弗·怀特咨询公司分析。残余评级反映了在提出缓解措施后的可能性和影响。

16 Oliver Wyman 2026 年 CEO 与科技领袖关于自主人工智能和 IT 的平行调查，2026 年 7 月

只有首席信息官才能做出的决定

附件15：工程运营模式下的CIO决策集

决定	建议	必要条件
投资焦点	专业知识和审查能力，与... 相对 为了更大规模地生成代码	过程中间 饱和，以及真正的优势 在开始和结束
代理采用	根据作品的核实程度进行采纳，设定一个可衡量的吞吐量基线 类型和任务类型：已存在广泛用途 绿地和锅炉房，配备高级 遗留系统评估	
质量关卡和验证	强制性测试加入人工智能辅助审查；审查和测试能力规模与 使用工具进行验证。不要仅依赖产量。 对人类警惕性的思考	
测量	衡量您自身的管道吞吐量，供应商基准被视为 船只的质量和值	依语境而定和利用 而非作为证据
形式增强	现在以Copilot风格进行序列，并介绍 具有完全自主能力的代理机构，例如 准备好才组队	主动治理 以及自主代理 已就位
责任与激励措施	指定负责人员 被赋予权力并受到激励去关心 长期结果	持续的仪器测量和 持续监控价值 成本和风险
才能	招聘领域专家并保护 初级人才梯队	技能和专业知识是稀缺的。 资源

奥利弗·怀曼分析。

专注于代码生成的公司，在更远的未来会遇到瓶颈。

每个控制面板都会显示您的工程师在产出更多代码，但这数字可能具有误导性。原始代码的规模目前很廉价且容易；但剩下的困难之处，以及区分劣质软件与优质软件的关键，在于评审能力、验证以及领域判断。这些都不会随着代理输出的增加而自动扩展。将代码生成视为基础设施，通过设置关卡和基于工具的验证，而非监督。根据验证和衡量工作容易程度来决定使用代理的位置，并依据贵公司的实际成果而非代理供应商的营销数据来做决策。然后，将释放出的投资投入到领域专业知识、评审能力以及初级人才管道中。

真正的问题，与其说是你能产出多少代理输出，不如说是你能坚持多少，以及任何人实际上需要多少。还有，五年后你是否仍会有能理解这些的员工。

交付与运营

代理人应在生产中拥有何种授权

1

意图要求与意图
稀缺：清晰

2

构建工程稀缺：验证

3

运行配送与运营
稀缺：控制

能力不等于权威。可核查、可撤销的权力要下放；不可核查、不可撤销的权力要掌控。

代理人能否安全地运输和操作软件，还是仅仅编写代码更快？

上下文

虽然代码开发可能正变得像商品一样普遍，但安全地交付和运营软件仍然充满挑战，并且持续获得的关注远远不够。主要平台已经支持在持续集成和持续部署（CI/CD）——即构建和部署代码的流水线——上进行代理式工作。现在，代理也开始承担站点可靠性工程（SRE）的任务，确保系统稳定运行、响应故障事件以及管理基础设施。

这个问题已超越了代理人是否能在技术上执行这些任务。真正的问题在于，代理人可能会做出什么样的操作决策，在何种限制条件下，以及如果出错会采取何种补救措施。这种区别将数据平面（如本地化工作，如补丁和重跑）与控制平面（规则：配置、部署策略、审批关卡）区分开来。

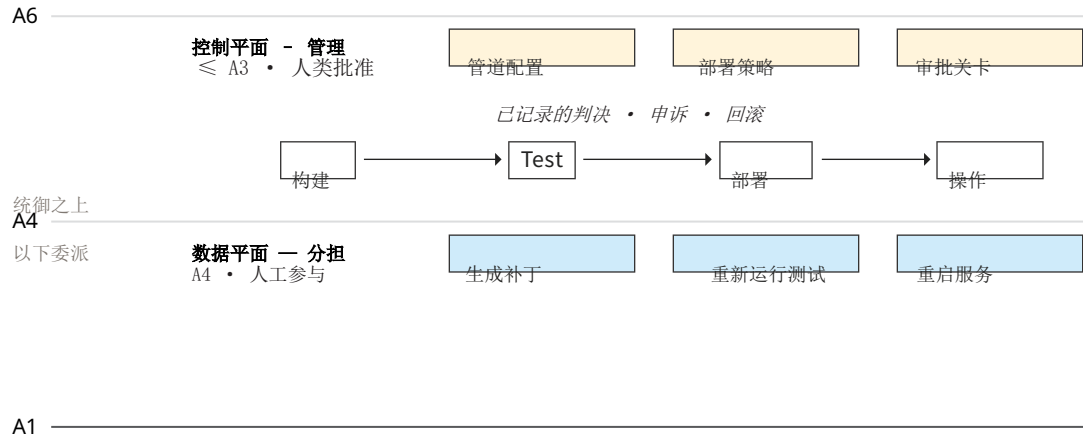
在合适的条件下，如今的代理机构可以安全地承担数据平面工作。将控制平面自主权交给它们则尚待验证，且那里的错误可能会以机器速度扩散。对于一家运行在传统基础设施的大型企业而言，实际问题在于权限：要转移什么、如何治理它，以及组织是否能在事后重建代理机构所做的工作。

数据平面和控制平面

数据平面关乎本地化、可逆的操作：生成补丁、重新运行测试、重启服务。控制平面是生产规则手册：管道配置、部署策略和审批关卡。

巴恩斯、加莱布与哈桑，《代理式CI/CD与权限转移》，2026年。

图16：数据平面与控制平面



奥利弗·怀曼分析。

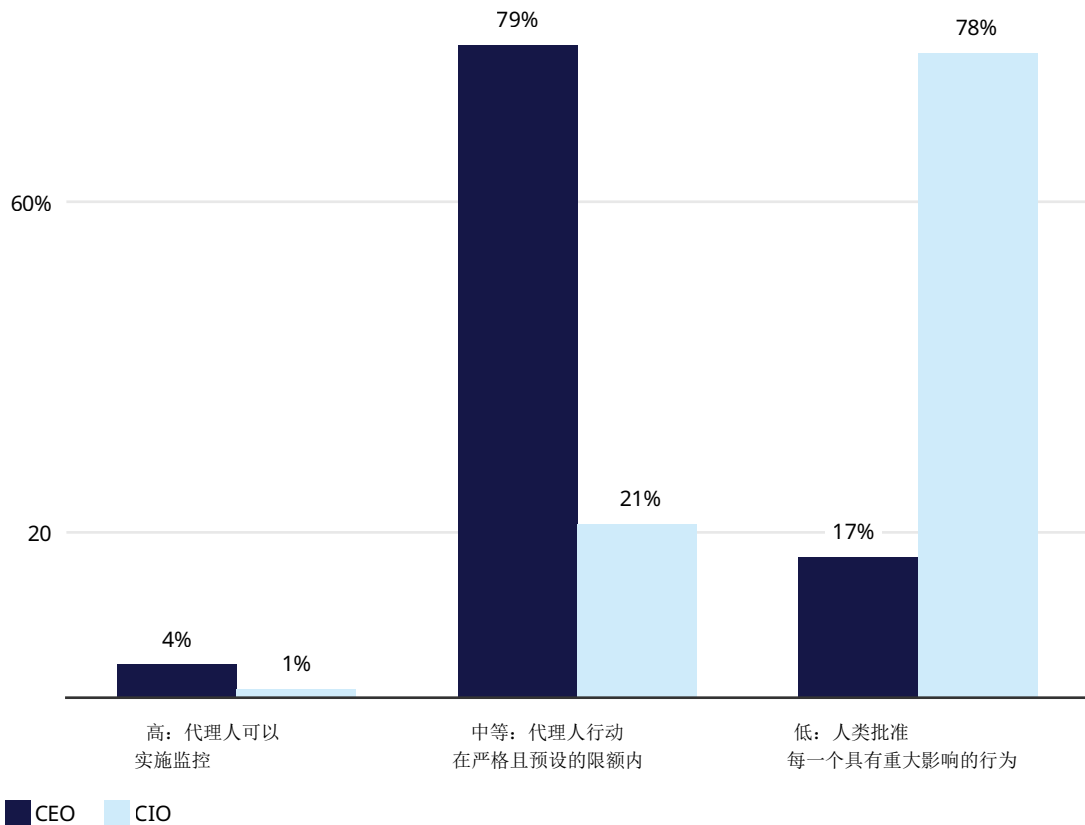
我们的观点：保持部署策略的人为控制

我们相信从有限的自主性开始会更好。企业应让代理承担数据平面工作，但将控制平面权限保留在人类手中。

这些公司在数据平面上赋予代理机构自主权的大小，应取决于其下方的交付系统：发布流程和记录必须可靠，团队需要一种共享的方式来判定发布的紧急程度。代理将运行的平台应可观测，并在代理引入之前就准备好。架构本身必须在设计上包含爆炸半径，因为这些故障模式可能迅速蔓延。SRE 纪律也需要延伸至代理，将交付稳定性与采用率一同衡量，以便激励措施能够强化重要成果。

调查数据展示了有界自主性的需求。人们感觉到CEO愿意授予的自主性与CIO目前部署的自主性之间存在脱节：大多数CEO倾向于设定严格、预设的限制，而大多数CIO则报告在需要人工批准的层面上运行。

第十七项证据：CEO们倾向于有限自主权，而部署的代理仍然依赖人工批准



来源：奥利弗·怀曼 2026 年 CEO 与科技领袖关于自主人工智能和 IT 的平行调查，2026 年 7 月。注：CEO 和 CIO 的回答分别来自不同的样本，并反映了不同的问题；比较具有方向性。

快速修复场景向我们展示了该划定界限之处。当关键服务出现故障时，代理可以映射风险并准备修复方案。然而，在非正常时间窗口外部署变更属于控制平面操作，应保持人为控制和记录。这也是人们最想跳过这些步骤、将修复工作交给代理的时刻——这正是区分的重要性所在。

控制平面治理应易于测试。如果代理能够更改部署策略或清除审批关卡，且无需人工控制且无任何记录，则控制平面不受治理。如果事后无法重建是哪个代理更改了什么以及其权限归属，情况亦然。在建立这些控制措施之前，应暂停控制平面的授权；构建治理和审计追踪是必须首先完成的关键工作。话虽如此，目前大多数公司距离这一目标还有相当差距，仅有10%的公司能够按需提供每个生产代理的所有者、范围、成本和最后认证日期。58%的公司拥有部分这些属性，而29%的公司完全没有中央注册记录。¹⁸

¹⁸ Oliver Wyman 2026 年 CEO 与科技领袖关于自主人工智能和 IT 的平行调查，2026 年 7 月

10% 的组织能够按需提供每个生产代理的所有者、范围、成本和最后认证日期。无法被列出的控制平面无法被治理。

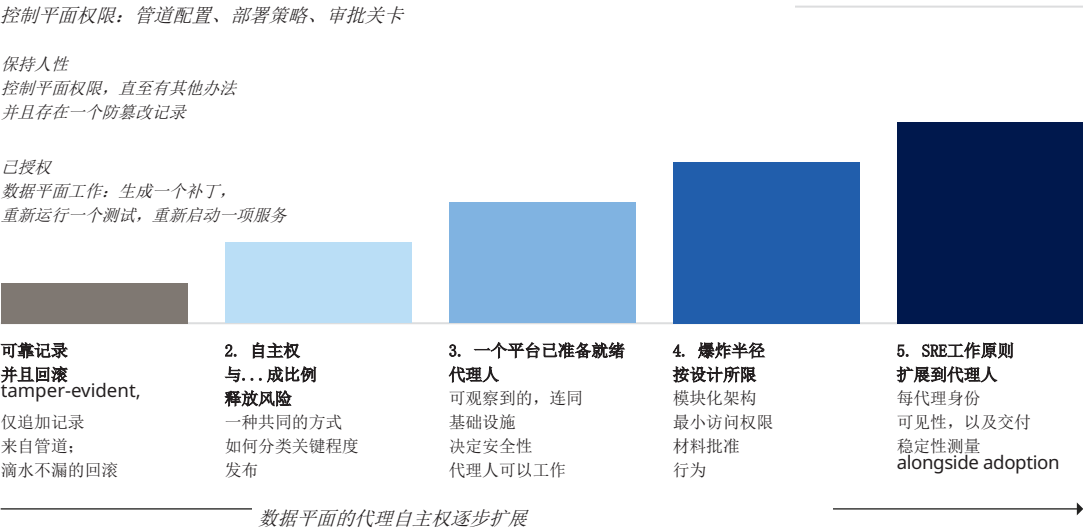
第18项证据：当投资和关注转移时

From	To
自主部署或配置更改而不 如果出问题，可以采取的措施	边界自主：数据面委托，控制 受控飞机
定制化，按团队发布的管道系统	一个具有标准的内部开发者平台 常用路径
将代理置于现有栈上并寄希望于	代理就绪、可观测的基础设施： API操作，按代理身份区分，遥测数据
原则上不负责任，且无记录	一个带有回滚功能的防篡改决策记录 并且一个紧急停止开关
将代理操作视为任何其他应用程序	设计限定了爆炸半径
将收养指标误认为交付健康	代理人的SRE：衡量吞吐量和稳定性
吞吐量作为主要指标	平均修复时间作为首要交付关键绩效指标

奥利弗·怀特咨询公司分析

扩大配送和运营中代理自主权的五个条件

附件19：当满足五个条件时，自主性扩展到数据平面；控制平面保持人为操作



来源：Oliver Wyman分析（示意图）。下文所述条件：数据平面和控制平面定义见附表16。

1

若要移交自主权，您的公司需要从可靠的记录和回滚机制开始，以便在出现问题时进行修复。这始于一个防篡改、仅追加的记录，该记录将每一项技术操作与批准来源以及该代理批准的基础联系起来。然而，目前只有25%的组织拥有这种审计追踪，而72%的组织只有部分日志。

在此最佳实践做法是直接从管道生成这些记录，而不是事后添加。测试和回滚必须万无一失，具体要求包括：明确的回滚流程、代码和数据的版本控制、分阶段的A/B部署，以及关键数据集的双向测试。然后，这个基础可以支持自动化的早期预警检测。

2

并非每个发布都带有相同的企业运营风险。企业可以通过建立一套前厅、技术以及第二和第三道防线都认可的分​​类体系，来为比例控制和代理自主权的逐步扩展创建一个共同的基础。该体系应通过重要性（变更规模和潜在影响）来衡量和分类发布。

19 Ojewale, Suresh与Venkatasubramanian, 《LLM/代理工作流的审计追踪》，2026年。 20 Oliver Wyman 2026年CEO与技术领袖关于代理式AI与IT的平行调查，2026年7月。

紧迫性（时间敏感性）。人工智能本身可用于通过映射依赖关系和交叉引用服务级遥测数据来协助进行这些分类，但其目标和激励措施必须与执行交付工作的代理保持界限分明、相互独立。一旦所有相关方就分类达成一致并将其融入流程后，自主权可根据发布的关键性而有所不同，并随着代理生态系统首先在高容量、低风险工作上证明自身价值而扩展。

3

一个代理所能达到的安全程度，永远取决于其运行的平台。在安全方面，开发者平台和底层基础设施的重要性，超过了代理的智能程度。在这种情况下，代理的准备工作取决于四个能力。动作必须作为安全的、带有内嵌策略检查的应用程序编程接口（API）提供；代理需要关于资产、依赖关系和所有权完整可靠的上下文数据；堆栈需要带有每个代理的数字身份的内嵌控制；以及命名问责制，以及适当的生命周期管理、互操作性和包含推理成本监控的上下文管理。²¹ 没有这四个要素，堆栈就没有准备好进行安全的扩展。

4

现代人工智能模型本质上具有不可预测性，且并非为提供保障而构建。它们可能以多种方式失效：模型可能在提示阶段被误导而违背自身规则，或获得超出预期的权限。一个代理的错误也可能级联影响到其他代理——升级的速度可能比人类反应更快。

精心设计可以控制“爆炸范围”。解耦和模块化的架构、赋予代理最小化访问权限、限制其工具访问以及要求对重大操作进行审批，都是有效的控制方法。检测也必须自动化，因为仅靠人工审核无法跟上节奏。

最安全的系统仍然是那种受周边治理支持的有限自主系统。即便是迄今为止发布的最具自主性导向的供应商操作手册也坚持这一原则：其自主维护循环仍然保持检测的确定性，通过违规严重程度限制代理可以执行的操作，并且在最高自主性级别下仅允许代理提出行动建议——一个等待审核的拉取请求，或是一个预先批准的运行手册。²³

²¹ Chan, Wei, Huang, Rajkumar, Perrier, Lazar, Hadfield & Anderljung, 《面向AI智能体的基础设施》，《机器学习研究交易》，2025年；NIST NCCoE, 《加速软件和人工智能智能体身份与授权的采用》概念草案，2026年2月。²² OWASP GenAI Security Project, 《2026年OWASP智能应用前十名》，2025年12月；Krawiecka & Schroeder de Witt, 《扩展OWASP多智能体系统威胁建模指南：多智能体安全研究的洞察》，2025年8月；Ken Huang, 《智能AI威胁建模框架：MAESTRO》，云安全联盟，2025年2月。²³ Anthropic, 《原生AI SDLC手册》，2026年8月。

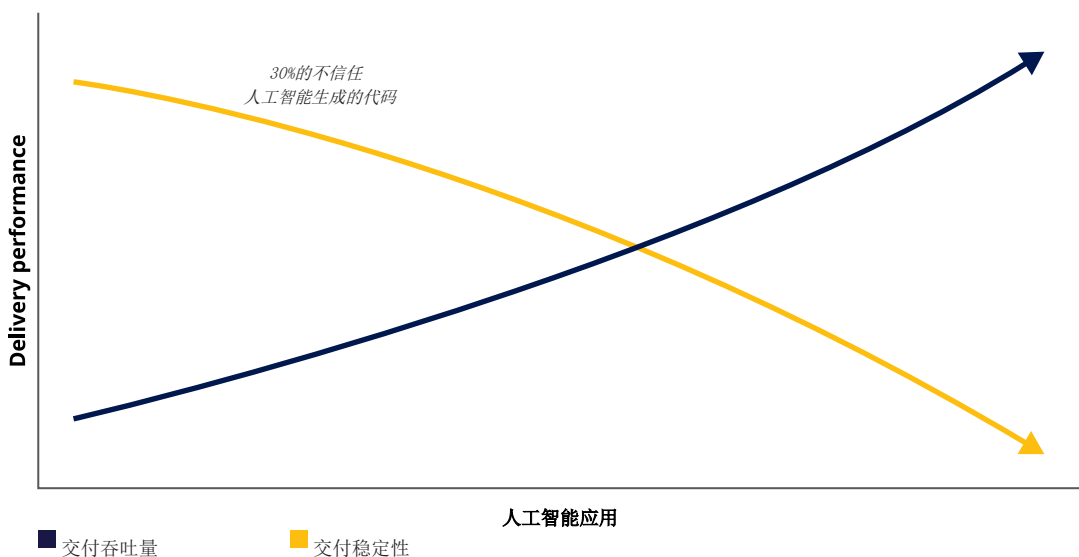
5

将代理引入生产仅是工作的一半。另一半是安全地运行它。操作员需要强大的按代理身份进行管理、对可能是一个黑盒的内容有可见性、在失败情况下有备用计划、持续评估以及防止对正在生产的内容进行非预期更改的控制。²⁴ 数据收集——或遥测——也必须反映这一点：一条指令可以扩展为 dozens of tool calls、sub-agent delegations 和 retries。

人工智能的采用可能会提高配送吞吐量，但也可能增加配送的不稳定性。大约30%的受访者还报告对人工智能生成的代码很少或完全没有信任。

使用现代SRE实践来衡量交付性能，尤其是吞吐量和稳定性，而不仅仅是衡量采用率。同时也要追踪已发布内容的运行成本：运营负载和攻击面随着已上线功能而扩展，而非随着代码编写而扩展，因此未使用的功能应像新批准的功能一样被审慎地淘汰。在所有这些基础工作就绪后，这些衡量标准能够使交付和运维代理人员承担责任，同时确保它们得到监控和优化，以实现预期目标。

展品20：若管理不当，人工智能加速交付但会降低稳定性



来源：DORA (Google Cloud)，2025年人工智能辅助软件开发现状

²⁴ Stevan Malesevic & Christopher Heiser, 《AI在SRE中的应用：谷歌如何部署自主AI以改进运营》, “谷歌云博客”, 2026年5月28日。²⁵ DORA (谷歌云), “2025年AI辅助软件开发现状”。

五种材料风险

某些风险只有在软件投入生产后才会显现。在下表中，我们重点列出了五个主要的潜在关注点：

图21：下游显现的风险

Risk	机制与缓解	残余的	所有者
无政府状态 control-plane 权威	代理被授予超出数据平面的权限。 未经外部监督、救济或篡改 证明记录。然后它修改了部署策略或 通过审批关卡，并且错误（一个多 （代理级联或失控升级）很难 停止且难以追踪。 修复：保持控制平面为人所有，并 已记录的判决和爆破半径控制 并逐步测试和学习，范围不断扩大 数据平面的代理自主程度		VP 工程 平台
代理人 on an 不成熟平台	代理被部署到非中高档的基础设施上。 代理就绪，因此他们无需特定权限即可行动 每个代理的身份或遥测数据，以及何时发生事件 发生，根本没有办法控制它们或 追溯发生的事情。 修复：为资金代理机构准备、可观察的基础设施 first.		平台 / SRE
自动化 自满	随着代理接手常规工作，值班工程师中等到偏高 橡皮图章式的代理人所提出的补救措施，警报疲劳 开始生效，系统知识会逐渐淡忘。当 新奇的案件超出了代理人的范围，无人保留 解决它的深度。与此同时，“零运维”拥有 增加了一层，必须进行的操作。 maintained. 修复：强制代理人员记录和描述他们的 采取自身行动并实施全面的遥测。 保持人类远离高风险行为，以免他们的技能被 萎缩，通过实际操作进行轮岗 工作，并将新层视为一个运行系统，而不是 一个黑匣子，不要碰。		SRE + 平台
撕换 传承核心	公司将现代化视为实施MEDIUM的前提条件。 代理机构增加价值——因此，进行大规模核心替换 程序停滞，推迟能动性价值并提升 迁移敞口 修复：将其包装并与现有骨干集成 与其替换它。		首席信息官 + 建筑
管理风险时 机器运行中 速度	缺乏足够的制衡机制，代理行为将 代码生成和交付可能导致急剧 风险增加，运营韧性减弱 并扩大了潜在网络攻击的目标范围。 运营负载和攻击面随着每一次增长。 无论是否使用，该功能都保留在生产环境中。 修复：基础设施上的护栏，代理机构 堆叠，以及测试/控制流程都必须 保持或超过多少速度 赋予工程自主代理。	MEDIUM-HIGH	SRE + 平台 (与首席信息安全官)

来源：奥利弗·怀特咨询公司分析。残余评级反映了在提出缓解措施后的可能性和影响。

只有首席信息官才能做出的决定

附件22：首席信息官决策集交付与运行

决定	建议	必须首先成立什么
代理权限 CI/CD	数据平面当前：仅当回溯与决策被记录时才使用控制平面。 一个防篡改记录存在。	回滚功能存在。
平台	一个标准化的内部开发者平台，具有明确的 为人熟知的途径。	平台在资金到位前 代理部署
基础设施	代理就绪：具有策略检查的API操作，按代理划分 身份、作用域权限和遥测数据。	损害是可控的， traceable.
运营和 可观测性	代理人的SRE；特定代理的遥测；衡量 功能资产的整体吞吐量、稳定性及运行成本 并且补丁以多快的速度达到发布，对于关键来说 services.	可靠性目标和 交付基准是 针对代理行为定义。
追索和审计	防篡改、仅可附加的决策账本， ²⁶ 回滚和强制停止开关。	记录被生成 直接来自管道 而不是 retrofitted.
遗产	整合并封装——将现代化视为输入，遗留骨干系统可以 与其说是先决条件，不如说是过程本身。	暴露受管理的 API。

奥利弗·怀曼分析。

代理人（或：中介人）的能力与其被授予的权限并不相同

。

对下游代理的讨论通常从其能力开始：该代理能否部署或自我修复。在生产环境中，其被允许执行的操作更为相关。一个代理可能在技术上具备更改部署策略的能力，但这并不能证明在没有人工控制或无法撤销其决策、并记录其决策的情况下，就应赋予其此权限。操作模式应将委派的数据平面工作与受监管的控制平面权限分开。平台必须执行这一边界，保留足够记录，以便部署该平台的公司能够在事件进展速度超过人工人员反应能力时，重建和撤销代理所执行的操作。

26 Oliver Wyman 2026 年 CEO 与科技领袖关于自主人工智能和 IT 的平行调查，2026 年 7 月

关于商誉——由 Oliver Wyman 开发的 AI

Oliver Wyman 的“商誉AI”（Quotient, AI）将深厚的行业洞察力与实用的AI专业知识相结合，旨在提升绩效、增强韧性、调动资本并驱动增长。我们与组织紧密合作，助其自信扩展规模，构建持久优势——将AI的潜力转化为实际成果。

威灵顿咨询公司（Oliver Wyman），Marsh（纽约证券交易所代码：MRSH）旗下的业务部门，是一家管理咨询公司。该公司凭借深厚的行业洞察力、大胆的创新精神以及一种能够化繁为简、协作共赢的方法，助力组织应对其最具定义性的转型时刻。Marsh 是全球在风险、再保险与资本、人力资源与投资以及管理咨询领域的领导者，为130个国家的客户提供建议。公司年营收达270亿美元，拥有超过9.5万名同事，致力于通过独特的视角，帮助客户建立信心，实现蓬勃发展。

欲了解更多信息，请访问 oliverwyman.com，或在领英（LinkedIn）和推特（X）上关注我们。

美洲 +1 212 541 8100

欧洲 +44 20 7333 8333

亚太区 +65 6510 9700

印度、中东和非洲
+971 (0) 4 425 7000

AUTHOR(S)

泽维尔·博伊洛

Partner, Technology Innovation Europe
xavier.boileau@oliverwyman.com

马克西姆·哈皮

Principal, Technology Innovation Europe
maxime.happy@oliverwyman.com

德·蓬莫罗尔 (Dé · Péngmòluó' ěr)

Partner, Technology Innovation US
charles.depommerol@oliverwyman.com

麦克道尔 (Màikè Dàowù' ěr)

Senior Delivery Lead, Technology Innovation Europe
vera.mcdowall@oliverwyman.com

萨米尔·贾维里

Partner, Technology Innovation Europe
samir.javeri@oliverwyman.com

拉米罗·德·洛萨 (Lāmī luō · Dé · Luòsà)

Director, Technology Innovation Europe
ramiro.delarosa@oliverwyman.com

版权所有。未经 Oliver Wyman 书面许可，本报告不得全部或部分转载或重新分发。
在此方面，奥利弗·怀曼对第三方行为的任何责任概不承担。

本报告中的信息与观点由 Oliver Wyman 撰写。本报告不构成投资建议，亦不应被视为投资建议或替代就相关事宜咨询专业会计师、税务师、律师或财务顾问。Oliver Wyman 已尽一切努力使用可靠、最新及全面的信息与分析，但所有信息均未经保证，亦不构成明示或暗示的任何保证。Oliver Wyman 不承担更新本报告中信息或结论的责任。对于因依据本报告或本报告中引用的任何报告或信息来源所采取或未采取的任何行动而导致的任何损失，或因任何后果性、特殊或类似损害，即使已被告知此类损害的可能性，Oliver Wyman 亦不承担责任。本报告不构成买卖证券的要约或招揽买卖证券。未经 Oliver Wyman 书面同意，本报告不得出售。

OLIVER WYMAN
A MARSH BUSINESS

| HAWK

管理AFC代理

模型治理与验证如何演变以适应具有自主行动能力的AI在金融犯罪合规领域的应用

摘要

金融机构正开始在反金融犯罪（AFC）系统中部署具有自主性的AI，而监管环境仍在不断演变。现有的关于模型风险管理（MRM）的监管指南、如欧盟AI法案等新兴的横向AI治理框架以及行业在金融犯罪中应用AI的原则，都提供了重要的治理原则。然而，这些都没有为具有自主性的AFC系统提供一个完整的框架，后者的自主规划、工具使用、动态工作流程和授权决策带来了独特的治理问题。

本文提出了一种适用于机构当前应用的自主金融科技公司（AFC）系统的实用治理框架。该框架并非取代现有指导方针——包括跨机构模型风险管理指导、沃尔夫斯贝格人工智能原则以及金融行动特别工作组（FATF）关于人工智能的工作——而是确定了在现有监管指导方针中仍然适用的治理原则，并引入了管理在AFC环境中运行的自主系统所需的额外控制措施。

全文中，我们以美国货币监理署（OCC）跨机构模型风险管理指南为例，因其提供了一个为许多合规和模型风险团队所熟悉的治理生命周期，阐述了现有治理原则如何扩展应用于自主式自动柜员机（AFC）系统。由此产生的建议旨在本身作为一个治理框架，适用于自主式自动柜员机系统，并可适用于不同的监管和监管体系。

无论是内部开发还是向第三方采购，每个物料代理人都应连接到企业代理保证层，该层允许机构进行配置、测试、观察、挑战、约束和停止系统，并保留用于监管的证据。

核心论点是，有效的监督必须从管理独立模型转向管理更广泛的代理系统。该系统的固有物质性由业务用例决定，但其残余风险以及其所需的相应治理和控制可以通过围绕自主性、工具权限、工作流约束和运行时安全措施进行的工程选择来塑造。采用这种更广泛的治理视角的机构将能更好地部署安全、有效且符合不断变化的监管预期的代理式人工智能。

内容

摘要2

在专门的指导方针出台前，为AFC管理代理式人工智能 4

2. 定义代理式AFC系统 7

3. 将现有治理原则应用于能动型AFC 9

4. 代理风险与基于风险的实质性框架 11

5. 代理开发与系统使用 16

6. 代理验证与监控 19

7. 治理、控制与权限 26

8. 供应商和第三方代理解决方案：无责任转移的保障 28

9. 示例：一名反洗钱调查代理人员

10. 从框架到制度实践 35

11. 结论 36

在专门的指导方针出台前，为AFC管理代理式人工智能

反金融犯罪计划正进入一个注重实效的时代。美国的方向——反洗钱法案强调对政府“高度有用”的信息、转向结果导向的审查，以及监管姿态从重流程、对框框进行核查转向——正推动机构走向基于风险、以结果而非活动来衡量成效的计划。在此背景下，金融机构正采用自主型人工智能用于调查及其他合规活动中，以加强其反金融犯罪风险管理并提升其计划质量，且通常早于任何关于如何治理这些系统的正式指导。这样做要求机构将问责、验证、监督和控制等既定原则转化为适用于能够规划、使用工具和行使授权的系统所需的形态。

这创造了一个实际的治理挑战。机构必须运用并监督一种全新的技术，而所使用的监管框架是为上一代分析和人工智能系统开发的。在网络安全、数据治理、身份与访问管理、隐私和运营风险等领域现有的框架解决了这一挑战的重要部分；然而，它们通常不提供针对端到端智能体系统的集成治理模型，包括其自主规划、工具使用、动态工作流程、授权委托以及与人类决策者的交互。在专门的治理框架出现之前，机构需要一种实用的方法，将当今的监管原则应用于智能体人工智能，并加以扩展。

现有的模型风险指引为持续有效的治理原则和当前框架的界限提供了有用的说明。2026年4月更新的美国跨机构模型风险管理监管指南，废止并取代了长期有效的2011年指引（SR 11-7/OCC 2011-12）以及2021年关于BSA/AML系统的跨机构声明。

2020年反洗钱法（AMLA），该法案要求银行特定反洗钱报告“极具价值”，并确立了国家反洗钱/反恐怖融资优先事项；后续的FinCEN及跨机构材料进一步强化了以结果和有效性为导向的方法。

与此同时，它明确界定了自身的边界。它将“模型”定义为一种复杂的定量方法，该方法应用统计、经济或金融理论来产生定量估计，并随后明确指出生成式和具身式人工智能不在其范围内——同时明确说明，这并非豁免控制：

生成式人工智能和代理式人工智能模型是新颖且快速发展的。因此，它们不属于本指南的适用范围。尽管如此，银行机构的风险管理和治理实践应指导确定本文件未涵盖的任何工具、流程或系统的适当治理和控制措施。

本文以此为基础展开。它并非取代现有的监管指南，而是识别出在当今框架下仍然适用的治理原则，并引入了管理实际运行中的代理式自动交易系统所需的额外控制措施。

代理机构（AFC）引入的基本治理挑战在于，对其核心中基础模型的训练过程缺乏影响力，也缺乏透明度。因此，治理必须围绕一个不透明的核心构建，利用机构能够直接管理的要素：代理机构的授权和操作指令、其数据及工具的访问权限、其被允许采取的行动、需要人类批准的环节，以及用于审查和重建其活动的记录。

机构可以借鉴既有的监管、风险管理及行业原则，但必须将这些原则转化为适用于更广泛能动性系统的治理方法。由于美国合规和模型风险团队最熟悉的是OCC跨机构模型风险指导提供的治理框架，我们将其作为实用的组织参考，而非作为自身的治理框架。我们还借鉴了更广泛的行业指导，包括沃尔夫斯贝格集团在金融犯罪合规中使用人工智能和机器学习的原则²，以及金融行动特别工作组（FATF）关于人工智能和深度伪造的2025年12月展望扫描³，后者因通过反洗钱/反恐怖融资（AML/CFT）视角明确将能动性人工智能列为新兴关注点而引人注目。

2 沃尔夫斯贝格集团，《在反洗钱合规中使用人工智能和机器学习的原则》（2022年12月）。其五项要素为：合法目的；合理使用；设计和专业技术；问责与监督；以及公开与透明。3 金融行动特别工作组，《前瞻性扫描：人工智能与深度伪造》（2025年12月22日）——通过反洗钱/反恐怖融资/反制洗钱与恐怖融资的视角，对与人工智能相关的风险和趋势进行的前瞻性评估，包括生成式人工智能和代理式人工智能。

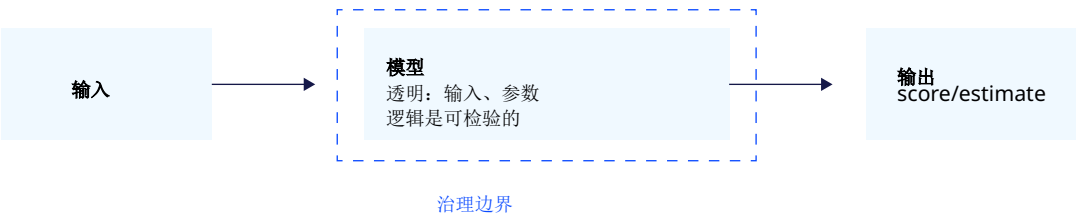
全文中，我们采用一致的三棱镜方法来审视现有的治理框架：（1）哪些原则仍然直接适用；（2）代理系统中出现哪些重要空白；（3）解决这些空白所需的额外控制措施。

贯穿全文的核心转变在于治理单元从模型转向代理系统——也就是说，该模型与其驾驭系统（即协调和调用工具的框架）、其可访问的数据、其可采取或推荐的行动、其升级求助的人类，以及其留下的审计追踪。

图1：从模型到 workflow：治理单元的扩展

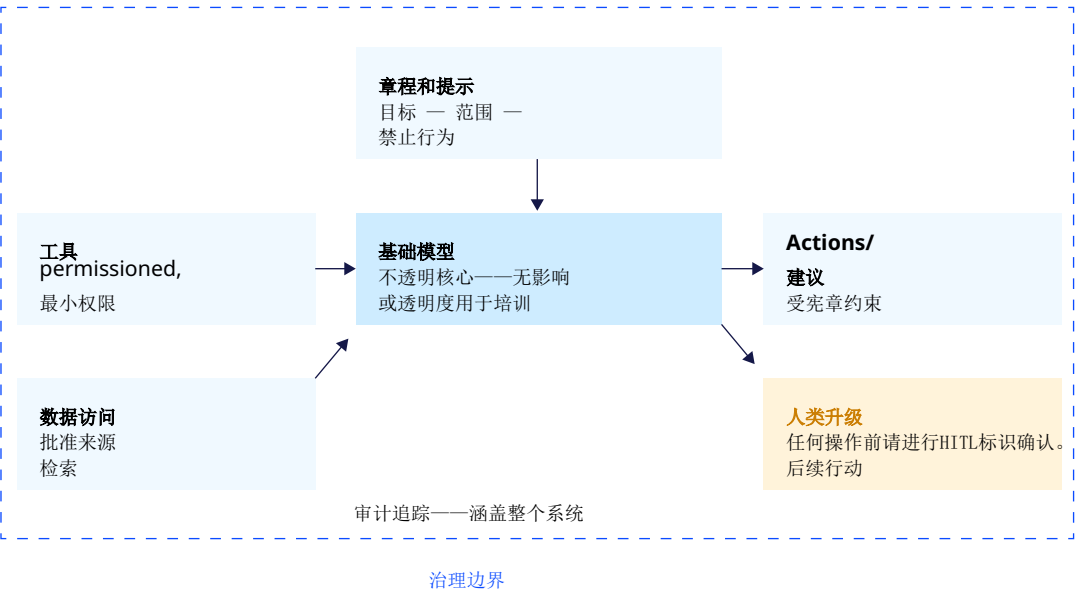
经典型号

该模型是治理的基本单位



代理系统

整个系统是治理的单位



欧文咨询和霍肯分析。

管理该扩展单元依赖于一个企业代理保证层，该层允许代理——无论是内部开发还是第三方提供——进行注册、测试、观察、控制和证明。

2. 定义代理式AFC系统

治理范围取决于被治理对象的定义。在本论文中，AFC代理被定义为一种有边界、具备人工智能的系统，该系统在批准的数据源和工具中追求调查或控制目标。AFC代理执行的活动可以包括，例如，收集和交叉引用证据、总结警报、排序调查步骤、识别类型、建议升级、起草可疑活动描述，或质疑案例的逻辑。我们互换使用“AFC代理”和“自主系统”这两个术语。两者均指这个复合系统——一个模型及其工具、数据访问、编排和控制——而不是指单个模型。

AFC代理并非单一的大型语言模型，也非聊天机器人。它更应被理解为一个组件系统，该系统组装起来以模拟调查员的业务流程，并包含推理模型、用于调用外部系统和数据的一组工具、记忆层或检索层，以及编排逻辑（该逻辑负责编排步骤）。这种构成方式正是为何代理不能作为单一模型进行管理的原因：其行为源于各部分以自身节奏变化的交互。

值得将智能体与传统人工智能以及无决策自主权的生成式人工智能区分开来，因为这种差异决定了治理方式：

表1：传统人工智能、无自主能力的生成式人工智能与能动式人工智能的比较

维度	传统人工智能	生成式人工智能 无自主权	代理型人工智能
核心功能	预测，分类，和 结构化数据	创建内容 对提示的回应	制定并执行计划 执行步骤的顺序 达到目标
自主性与行动	低 — 遵循明确指示 逻辑，从不主动发起	低 — 对...有反应 提示，不采取 独立行动	高一分解 目标，选择工具，和 行为或推荐
决策速度	毫秒 —— 为此而生 实时评分	秒到分	几分钟到几小时 — 精心策划了一场多 步骤工作流
决定论	高 — 相同输入 产生相同的输出	随机输出 可以不同	随机与路径 依赖行为 可能因运行而异
治理对象	模型（输入， 参数，输出）	模型加 提示	整个工作流程： 模型 + 工具 + 数据 访问 + 行动 + 人类升级+ 审计追踪

AFC代理涵盖广泛的应用场景和自主性——从调查副驾驶和欺诈分析师支持，到筛选处置、可疑活动报告（SAR）撰写、类型分析、风险暴露映射和系统优化。在设计驱动的自主性与对重大结果的内生邻近性方面，这种范围内的重要性差异巨大。

随着时间的推移，这一谱系中的重复设计可能会逐渐稳定为少数几个原型（例如筛选-处置代理或SAR起草者），每个原型都带有其特有的风险概况，并由此衍生出其特有的控制集。该学科仍在兴起，我们预期当今的机构会对代理逐一进行评估和批准；然而，随着投资组合的扩大，识别这些原型能够让常见且易于理解的设计基于共同基准进行验证并获得更快批准，同时稀缺的验证工作则集中于某个特定代理中真正新颖或高风险的部分。

图2：调查全生命周期中AFC代理的使用场景范围



AFC代理在警报和调查生命周期的使用案例——分析师审查之前、期间和之后

3. 将现有治理原则应用于代理型自动售货机

现有的关于模型风险管理、横向人工智能治理框架以及行业原则的监管指南，都为人工智能系统提供了宝贵的治理原则。尽管它们在范围和目的上有所不同，但它们都包含共同的主题：基于风险的治理、明确的责任、验证、持续监控、文档记录和独立监督。

自主式AFC系统并未使这些原则失效，反而揭示了现有框架的不足之处。自主规划、工具使用、动态工作流程和授权决策带来了治理问题，这些问题在传统模型治理中基本缺失，在更广泛的AI治理框架中也仅得到部分解决。因此，挑战并非要取代今天的治理框架，而是要扩展或增强它们，以涵盖更广泛的自主式系统。

表2以OCC跨机构模型风险管理指南为例，说明了该方法。OCC框架为许多金融机构提供了一个熟悉的治理生命周期，使其成为展示现有原则如何应用于治理代理式AFC系统（以及必须在哪里加以改进）的有用参考点。对于每个治理组件，该表格确定了：（1）仍然直接适用的原则，（2）代理系统引入的治理空白，以及（3）解决这些空白所需的附加控制措施。

自主式 AFC 在现有治理原则的基础上构建，但需要超越模型本身的控制机制。这些机制应涵盖代理自主性、工具使用、动态工作流、运行时监控以及对结果明确的责任追究等方面。

表2：应用和扩展OCC模型风险指引的代理AFC示例

OCC模型 风险组成部分	Similarity/applicability 为主动	指导中的空白 为主动	如何弥补差距
模型开发 implementation, 并且使用	定义预期 使用, 假设 目标, 测试 以及使用限制 直接适用 代理人	没有概念 授权 自主程度, 或 系统可以采取的行动 取或推荐。	定义代理权状: 有界目标 自主性/实质性层级, 授权 权威, 升级逻辑, 禁止行为
概念上的合理性	仍然有必要 为了评估是否 潜在模型(式) 设计精良且合身 为特定目的而设计; 适用舞台评论。	假定单一 统计模型具有 稳定输入/输出 关键挑战在于 绕过 不透明的基础 模型——沉默不语 提示, 工具选择 编排, 数据 访问范围	将合规性审查扩展到章程。 指令/提示, 工具权限 检索设计, 以及编排逻辑。
持续监测	持续表现 监控和 流程验证 保持关键; 漂移 检测适用。	静态输入/输出 监控疏漏 行为漂移 non-determinism , 并且提示/工具/ 模型更新 在评论之间	运行时行为监控 (路径和) 决策日志记录、将LLM作为裁判、护栏/ 异常警报, 由重新验证触发 材料配置或型号变更——不仅仅是 数据漂移
结果分析 可解释性	将输出与... 进行比较 预期成果与 解释决定 核心; 特性 可解释性水平 作为 SHAP — SHapley 值 附加说明) 仍然适用 任何贡献 统计模型。	Single-decision 分析不涵盖 多步推理 锁链, 证据 传承、引文或 一个组合的人 AI审计追踪。内部 工作原理可解释性 例如 SHAP 不适用于 不透明的基础 模型本身。	思维链级别的可解释性; 引文 时间戳记录的、防篡改的 源头的即时快照 已访问; 工作流路径的可审计性 已采取, 包括每一步的结果; 与AFC效能挂钩的结果指标 (例如提高搜救质量、降低误报率)
治理, 政策 以及控制 (角色/) authority)	董事会和高级管理层 管理 accountability , 独立挑战 清晰的角色分工 完全适用。	不映射决策 人与人之间的权利 代理人, 或定义 谁拥有代理人 跨AFC的行为 MRM 技术/供应商	定义人类决策权以及人- 闭环控制 (HITL) 控制; 分配代理 所有权; 使代理与人类意图保持一致; 向能动性发起独立挑战 工作流; 偏差/公平性测试; 常规 对数据鲁棒性测试 中毒攻击
模型库存 以及文件	保持 库存和 文档 适用。	库存设计 对于离散模型; 代理人结合 模型, 工具, 提示 以及数据连接 随着时间的推移而变化。	代理/工作流清单捕捉 组件、版本、权限和 修改历史; 将配置/提示视为 版本化的、有文档记录的工作件。
Vendor/ 外部模型	供应商模式- 风险原则 验证, 持续进行中 监控适用。	有限的指导 验证供应商 代理机构, 其 编排 部分不透明。	供应商代理验证与定制 控件; 工具/合同的透明度 数据; 持续联合监测; 客户 保留激活和决策权。

4. 代理风险与基于风险的实质性框架

在AFC领域，将统一治理模式应用于人工智能在操作上效率低下，甚至可能存在风险。将低风险内部负面媒体汇总工具与交易阻断代理置于相同的验证周期会导致资源瓶颈并延缓实施。相反，对交易性、高影响代理实施宽松控制则会引入显著的合规和运营风险。

为了安全且大规模地部署代理系统，机构需要建立一个基于风险的实质性框架，该框架能够根据代理活动的重要性来校准验证和监督。这种方法要求区分两个核心概念：

- **风险是对不确定性的前瞻性衡量。**它是发生概率（系统故障、幻觉或执行错误的概率）和影响（该故障带来的下游运营、财务或监管后果）的函数。
- **材料性是指客观存在的外部重要性门槛。**某一事件、决策或产出具有材料性，如果其发生、未发生或错报会影响到人类官员、审计师或监管者的决策。

在一个授权环境中，重要性是主要的筛选标准。通过首先评估业务流程的固有重要性，治理团队确立了监管基准。该框架并非试图从随机模型中消除所有风险，而是使用重要性来确定技术 harness 所需的稳健性。高重要性用例要求采用多层设计控制来降低残余风险，而低重要性用例则遵循简化的验证路径。

基于风险的实质性应反映用例的固有风险敞口及其技术控制的有效性。这使机构能够进行与其相称的治理，而无需将所有代理系统一视同仁。

4.1 代理系统的三分法风险分类

与传统的量化模型（静态且确定性）或独立的生成式人工智能工具（随机但交易性）不同，智能体式人工智能系统引入了复合风险敞口。尽管这三种人工智能类型之间的界限是流动的，但概念上可以将它们分为三元风险分类法：

经典模型风险（基础）

- 样本和数据偏差 • 过拟合与校准误差
- 概念和数据漂移

核心生成式AI风险（认知核心）

- 随机性及幻觉 • 提示词漏洞（注入攻击和越狱）
- 上下文窗口退化

独立代理风险（行动层）

- 规划失败与目标漂移
- 工具使用与API执行错误
- 级联传播（多智能体向量）
- 无界爆炸半径与不可逆性

4.2 双镜头物质性模型：固有属性与设计控制

新兴人工智能治理中一个常见的失败点在于将固有的物质性（或内在属性）与设计选择相混淆，也就是说，问题与解决方案的混淆。诸如“自主程度”或“工具访问权限”等因素并非用例的固有特征，而是工程师配置的技术控制手段，用以管理风险。

为建立一套有说服力的框架，机构必须通过双重视角模型来评估代理系统：

镜头1：纯粹的固有物质性（问题领域）

首个视角在考虑技术或治理控制的有效性之前，确立了用例的固有物质性。相关因素完全是外部的，在代理被设计之前完全由业务用例和运营环境决定。它们无法通过编写代码、调整提示或添加护栏来改变：

- **风险价值（金融风险敞口）**。指流程直接涉及的本金或交易量（例如，审核一笔100美元的零售交易，与管理一笔5000万美元的机构财库流动）。
- **流程关键性（运营风险）**。流程对机构持续生存的重要性。核心支付路由的失败会立即停止银行业务；而行政报告的失败 merely 仅会延迟一个内部周期。
- **监管和法律密集度（合规风险）**。管理该领域的法规框架（例如BSA/AML申报义务、OFAC制裁合规、GDPR或欧盟AI法案）。违规行为将面临固定的法律处罚和监管批评。
- **环境波动与摩擦（可逆性领域）**。目标系统的物理特性。修改内部数据库是低摩擦且完全可逆的；而写入公共账本或将文件提交给联邦金融情报单位则是高摩擦且实际上不可逆的。

镜头2：设计控制因素（技术整合）

第二个透镜评估技术 harness 如何限制风险敞口并降低残余风险。严格的设计控制或许能支持在更严格的参数下部署，但它们本身并不能改变问题领域的基本性质。这些是由开发团队（依据治理要求）强加的架构边界，用以限制代理的影响。

- **自主程度**。人机回路的设计配置，从辅助（“人在回路中”）转变为推荐（“人在回路外”）或自主（“人机分离”）。

这种双镜分类法的关键启示在于，设计选择充当了一个操作杠杆，用以主动确定代理部署所需的验证、监管、监控和控制水平，这也可以被描述为分配给代理的治理层。虽然机构无法改变业务领域的固有实质性，但可以通过有意的工程约束直接操纵剩余的治理层。

通过内在物质性和设计控制因素这两个双重视角来评估代理性用例，使机构能够将系统映射到四个不同的治理层级之一。这种分类决定了后续章节中规定的具体控制集。

表3: AFC代理机构的治理层级示例

治理 tier	代表 AFC示例	固有轮廓 (问题空间)	设计边界 (解空间)	核心治理与 验证措施
一级 低 (辅助)	负面媒体 摘要 (一个代理被用) 汇编和 总结 新闻文章用于 分析师评审)	- 低财务价值处于危险中 - 非关键流程。 - 最小化监管报告密度 - 低环境friction.	自主性: 辅助 (human-in-the-loop). 动作空间: 读 仅; 无系统写入 access. 断路器: 基础 会话时长和 令牌大写	- 第五章 (神): 已批准提示模板; 模型版本锁定 - 第六章 (估值): 中央库存注册; 用例对齐检查 - 第7章 (政府): 标准问答输出采样 - 第8章 (供应商): 标准第三方派对安保评估
二级 中等 (Analytical)	反洗钱调查 SAR草稿 代理 (An agent) 聚合 了解你的 Customer, 构建时间线 以及草稿 搜寻叙事 (用于签字确认)	- 轻度经济/运营影响 - 间接支持监管流程 - 可完全逆转环境 (人类) 审阅草稿。	Autonomy: 推荐 (human-on-the-loop). 操作空间: 只读 或高度受限 内部 写入权限 断路器: 输入/输出提示 注射过滤器	- 第五章 (开发): 强制性书面代理章程; 严格RAG基础定位 - 第六章 (价值): 黄金数据集测试; 覆盖费率监控 - 第7章 (政府): 四人联签关于推荐; 分配老板 - 第8章 (供应商): 验证租户隔离数据处理
三级: 高 (Supervised)	PEP筛查 处置 自动驾驶 (一种) 代理 自主地 清除低风险 误报 并升级 matches).	- 交易量高风险敞口 - 核心监管合规流程 (例如, PEP/制裁筛查) - 适中的环境的friction.	自主性: 受监督 行动 (人-) 审批循环) 动作空间: 中等 写入权限 自动化API调用 断路器: 真实 时间交易率 以及容量限制。	- 第五章 (草稿): 已编撰的政策转换为顺序工作流; 严格保密管理 - 第六章 (估值): 运行时执行追踪; 子群体偏差/公平测试; 红队演练 - 第7章 (政府): 密码学委托工作负荷标识实时性能telemetry. - 第八章 (供应商) 沙盒验证 独立代码审计 供应商逻辑
四级: 关键 (Autonomous)	自动化 逃避制裁 阻断者 (一种代理) 阻挡线 转移和 冻结资产 在交易中 发动机级别)	- 高经济价值处于危险中 - 存在主义关键流程 - 密集监管/法律监督 - 不可逆转环境 (立即冻结)	Autonomy: 自主 (human-out-of-the- 循环; 异常 仅升级) 动作空间: 交易写入 阻止权限 断路器: 自动化的, 硬件的 隔离式杀开关	- 第五章 (开发): 隔离执行沙盒; 独立评论家代理验证 - 第 6 章 (估值): 持续的 “大语言模型即服务” “审判” 审计; 数据中毒韧性测试 - 第 7 章 (治理): 董事会批准; 正式事件管控与回滚剧本 - 第8章 (供应商): 实时联合监控; 合同约定责任担保

例如，反洗钱调查代理人在一个合规要求极高的环境中运作。然而，通过严格设计系统采用推荐自主模型（二级），并拒绝其直接的交易写入访问权限（限制其行为范围），工程师们可以降低残余风险，并支持一种更受约束的部署态势。该系统遵循二级指南进行管理，避免了为四级系统保留的密集的、董事会级别的隔离开销。

相反，如果一个最初风险等级较低的Tier 1负面媒体摘要器被授予写入权限，能够自主向外部客户关联方发送电子邮件或更改客户关系管理（CRM）记录，那么其设计边界就发生了变化。这种设计扩展会立即将该代理推向Tier 3，从而触发强制性的严格验证要求（例如执行追踪、偏见测试和加密委托身份）。

因此，模型风险管理及合规团队必须将代理设计不仅视为一项工程任务，更应将其看作一个动态的治理旋钮。通过调整自主性、限制API工具集以及嵌入硬编码的断路器，机构可以有意减轻高度复杂用例的验证负担，实现速度与安全的平衡。

治理强度应随着代理人的剩余风险增加，而不仅仅取决于其用例。更强的设计边界可以支持低风险部署，而扩展的自主权、外部访问或不可逆操作则需要更严格的监管。

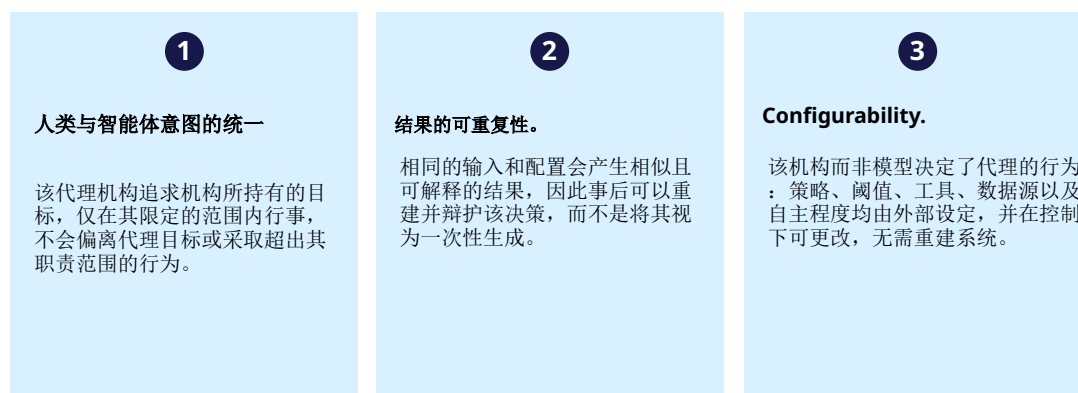
5. 代理开发与系统使用

现有的监管指南始终强调，人工智能系统在部署前应明确其目的、预期用途、已记录的限制，并经过适当测试。美国货币监理署的指南通过其期望来体现这些原则，即模型开发需与目的和用途保持一致，预期用途和限制需得到说明，且模型在首次使用前需经过测试。这些原则同样适用于代理式自动柜员机系统。

然而，治理应要求发展达成既定目标集，而非强制指定特定的系统构建方式。机构必须能够证明其代理满足这些目标；其实现方式是一种工程选择，这种选择会因具体应用场景、供应商以及机构的风险偏好而有所不同。由于低代码平台越来越多地允许几乎任何人构建接触敏感数据并执行操作的代理，因此构建过程本身需要与代理的重要性层级相匹配的监管措施。构建者从批准列表中选择模型、工具和数据；常见设计以模板形式提供；只有特定角色才能构建特定类型的代理；并且代理的权限属于代理本身，而非其构建者——因此，即使其创建者拥有写入权限，该代理也可以是只读的。

在实际操作中，许多此类控制需要通过机构更广泛的AI工厂内的企业代理保证层来提供。该层包含用于在机构范围内注册、测试、部署、监控、变更、暂停和证明代理所使用的共享技术和治理能力。其实施将取决于机构的云环境、代理 harness、评估工具、可观察性平台和现有的控制架构。这些选择可能会有所不同，但所需的结果不应如此：每个重要的代理都应该是可测试的、可观察的、版本受控的、可中断的，并且能够为独立审查提供证据。AFC应配置特定领域的策略、测试、阈值和决策权，同时依赖保证层来提供通用能力。

三个目标处于代理发展的核心。



基础文件是一份代理权章程：一份说明代理目标、其权责范围、被授予的授权以及被明确禁止采取的行动的书面声明。章程使得“预期用途和限制”对可行动的系统具有意义，并且它是所有后续控制（验证范围、决策权、监控）的参照依据。

章程是必要的，但不是充分的。实现目标取决于在共同决定代理人行为的各个要素中做出审慎的、有记录的选择：

1 系统提示和指令。 代理人的角色、运行人格、行为约束以及它在每一步都必须遵守的既定规则。

模型选择与版本锁定。 指使用哪个基础模型，以及固定其版本和解码参数的规范，以便能够一致地测试行为，并将结果的变化归因于已知的配置变更。

3 工具与权限。 代理可调用的具体工具，其读写范围设置为最小权限，以便一个被攻破或操作失误的代理所能造成的损害有限。

第四，数据访问与检索。 智能体可能使用的数据来源，以及使其基于已验证的当前信息进行检索的设计方案。

5 记忆与状态。 智能体在调查过程中保留的内部和跨调查信息，以及施加于该记忆的控制。

6 配置与控制流。 步骤如何排序，以及智能体被允许为自己规划多少，与遵循固定路径多少。

七道安全屏障：输入和输出验证、提示注入防御措施，以及内容和个人身份信息（PII）过滤器，这些措施均应始终有效，无论模型生成何种内容。

8 人机交互检查点和决策权。在代理采取行动之前，必须有人进行审查或批准。

9 评估和质量保证。测试框架和评估数据集，以及在必要时，用于在人类查看之前检查主要代理工作的质量保证代理或“评论家”代理。

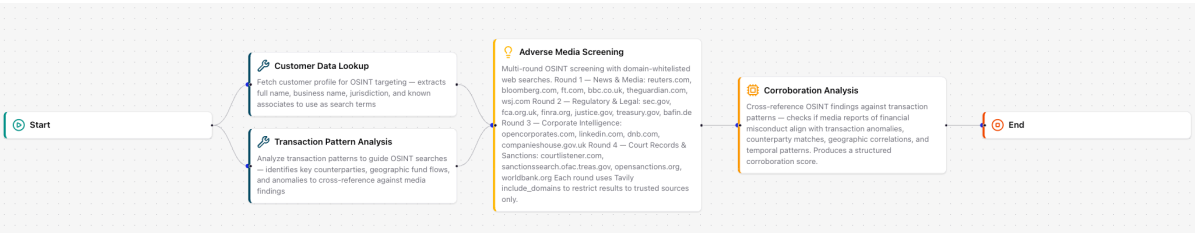
10 日志记录与可观察性。在构建时捕获的仪器配置，它使后续的监控和审计成为可能（第6章）。

采用工作流方法是把这些要素整合起来的有效方式。在这种方法中，机构的标准操作规程和政策被整合到代理人的工作流中。这是一个规定了代理人在每个步骤中必须或可以选择使用的工具、命名所需和可选的数据源、设置读写能力以及选择自主程度的一系列流程。

将代理约束为显式、基于策略的序列，可同时实现三个目标：意图直接编码在步骤中（对齐），允许的执行路径受到限制，且运行间的差异可追溯（可重复性和可审计性），以及每个步骤的工具、数据和自主性均可单独调优（可配置性）。代理严格在那些边界内运行，且在需要最终审核或判断的地方精确插入人工介入检查点。基于规划、更自主的设计也是可能的，并且可能适合低重要性场景，在这些场景中，目标保持不变，但保证负担更多地从设计时约束转移到运行时监控。

部署前的测试则评估各个独立组件（底层模型、检索质量、每个工具）以及集成工作流的端到端行为，评估方式是使用具有代表性的案例——包括边缘案例、模糊输入，以及旨在让代理偏离其职责范围的输入。

附件3：不良媒体和开源情报筛选工作流定义示例



Source: Hawk.

6. 代理验证与监控

6.1 验证范围

验证从未局限于模型本身。它还包括影响系统运行方式的数据、处理步骤、接口和控制。对于自主系统而言，该范围更广，因为代理可能依赖多个数据源、调用工具或服务并启动操作。因此，验证应涵盖用例和章程；数据和工具访问；指令和检索设计；输出质量与证据溯源；升级和人工审批点；以及变更管理、监控和结果。任何可能实质性影响代理行为或结果的组件都应纳入验证范围。

6.2 将既有的验证原则扩展应用于代理式自动售票系统

既定的验证原则仍然为自主式AFC系统提供了有用的基础，但需要将其应用于更广泛、更动态的对象。重点不再仅仅在于一个离散模型的性能；它还必须考虑智能体的设计方式、其使用工具和数据的方式、其在多步骤工作流程中的行为方式，以及这些行为随时间的变化。

以OCC框架为说明参考，三个熟悉的有效性原则尤其具有相关性：概念上的合理性、结果分析与可解释性，以及持续监控。每一项都必须扩展，以反映代理系统所特有的不透明性、非确定性、编排和授权。

1. 概念上的合理性。现有的监管指南强调从模型设计、关键选择、假设和开发证据等方面评估量化组件。对于自主系统，评估范围扩展到设计和编排的合理性，包括其章程、指令和提示、工具权限、检索设计以及编排逻辑。由于基础模型不透明，评估应侧重于可测试和控制的内容，包括输出质量、基于可靠来源的支撑、基准性能以及周边控制的有效性。

4 OCC 2026-13a，第五部分。模型验证的组成部分包括：概念合理性评估、结果分析以及持续监测。

2. 结果分析与可解释性。将输出与预期结果进行比较仍然是核心。单一决策分析无法捕捉的是代理人的多步决策和执行路径。对于代理而言，可解释性需要对其采取的步骤、调用的工具、参考的来源、应用的决策标准、产生的输出、置信度指标以及人类干预进行操作追踪。这些共同构成了“人类+AI”的联合审计追踪记录。结果指标应与AFC（自动化决策支持系统）的有效性挂钩，例如SAR（社会风险分析）质量提升和误报率降低，而不仅仅是任务完成。代理人相关的具体指标及其与单一模型指标的差异，在 § 6.6 中详述。

3. 持续监控。性能监控和漂移检测仍然至关重要，但静态的输入/输出监控会遗漏行为漂移、非确定性以及正式评审之间发生的提示、工具或模型更新。因此，监控变得需要关注运行时和行为——记录路径和决策，对护栏违规和异常发出警报，并使用校准的自动化评估，辅以人工抽样，以识别不受支持的声明和错误的引用支持。任何实质性配置或模型变更都会触发重新验证。

6.3 偏见与公平

代理系统能够通过基础模型的固有偏差、它们的提示、它们检索的数据或它们进行调查研究的方式编码或放大偏见。因此，公平性测试应该是明确且可衡量的。有用的指标包括针对受保护属性和代理属性（例如性别、年龄、种族或民族、国籍）以及代理（例如地理或基于姓名的民族推断）的子群体假阳性率和假阴性率——此外还有差异化影响率、人口统计均等性差异、平等机会/平等化几率差距、预测均等性（跨群体的平衡精确度）、组内校准以及平均几率差异。使用受保护属性或代理进行公平性测试应获得法律、隐私和方法论的批准，仅限于评估目的，并由足够可靠的数据支持。

没有单一指标是绝对准确的，而且多个指标无法同时满足。针对某一公平性定义（例如，人口统计学均等）进行优化可能会损害另一个（例如，均衡机会），因此机构应选择并记录适用于特定应用场景的公平性定义。这些指标在部署前使用经过筛选的“黄金”数据集进行评估，并在部署后进行持续监控，数据质量下降被视为重新验证的触发条件和升级事件。

6.4 对抗鲁棒性与安全测试

代理系统可能处理不可信信息并调用外部工具或服务，从而产生需要特定控制的 security risks。Prompt 注入发生在内容包含旨在改变代理行为的指令时。控制措施应包括将检索到的内容与系统指令分离、验证输入和输出、限制对批准来源的访问、集中管理操作指令、对数据和工具应用最小权限访问，并筛选传入内容和建议的操作。数据中毒发生在源数据或参考数据被故意操纵时。缓解措施包括使用批准和经过验证的来源、维护数据溯源和完整性控制、监控源数据的变化，以及防止代理范围的无控制适应或扩展。

这些控制措施应在部署前进行测试，并在部署后定期进行。机构应评估系统的攻击面，并开展旨在诱导超出范围行为、未经授权访问、数据窃取或工具误用的对抗性测试和渗透测试。发现的问题应进行严重性评级、修复并跟踪至关闭。事件响应程序应涵盖检测、遏制、暂停或回滚、根本原因分析、恢复以及任何必要的通知或披露。

6.5 可观察性与追踪

所有以上内容都取决于能够看清代理实际做了什么。可观测性是指系统地捕获每个运行中代理的完整执行轨迹的能力，包括每个提示和模型响应、中间推理步骤、每个工具调用及其结果、检索的来源以及延迟、token成本和错误等操作信号。在此上下文中，轨迹是针对每个决策的粒度记录，而指标则是从许多轨迹中得出的聚合值。

在实践中，这由一个专门的可观测性层提供——即新兴的LLM追踪平台——该平台将追踪信息写入一个结构化、可查询且防篡改的存储库，并依据该机构的记录保存义务进行保留。这一层将一个不透明、非确定性的系统转变为可监督的系统。它支撑着思维链审计追踪和运行时监控、漂移与质量指标，以及事后事件根本原因分析。没有它，代理的行为无法事后重建；有了它，每个决策都可以一步步回放。

为避免在每个用例中重新创建可观察性，机构应在企业代理保障层中定义一个适用于云、代理平台和供应商解决方案的通用追踪和证据标准。AFC特定的指标应输入该层用于追踪捕获、访问控制、保留、监控和事件调查的通用功能。

6.6 持续测量与漂移

一套实用的AFC代理监控方案结合了模型质量、数据及业务信号：精确率和召回率（通过已裁决样本、已知结果或验证性回顾测试进行估算；或通过分析师覆盖与代理正面及负面评估的对比进行评估）；误报率、任务成功率、引用准确率、偏差与公平性指标，以及人工覆盖率；数据漂移和概念漂移（“可疑”定义的变动）；以及调查解决时间等业务信号。每个指标都有阈值和警报，持续违规将触发审查、重新校准或回滚。对于代理而言，覆盖率特别有用：上升的覆盖率是早期信号，提示或节点表现不佳需要关注。反之，异常低或下降的覆盖率可能表明人工审查不足。

6.7 推广：领先者/挑战者与分阶段部署

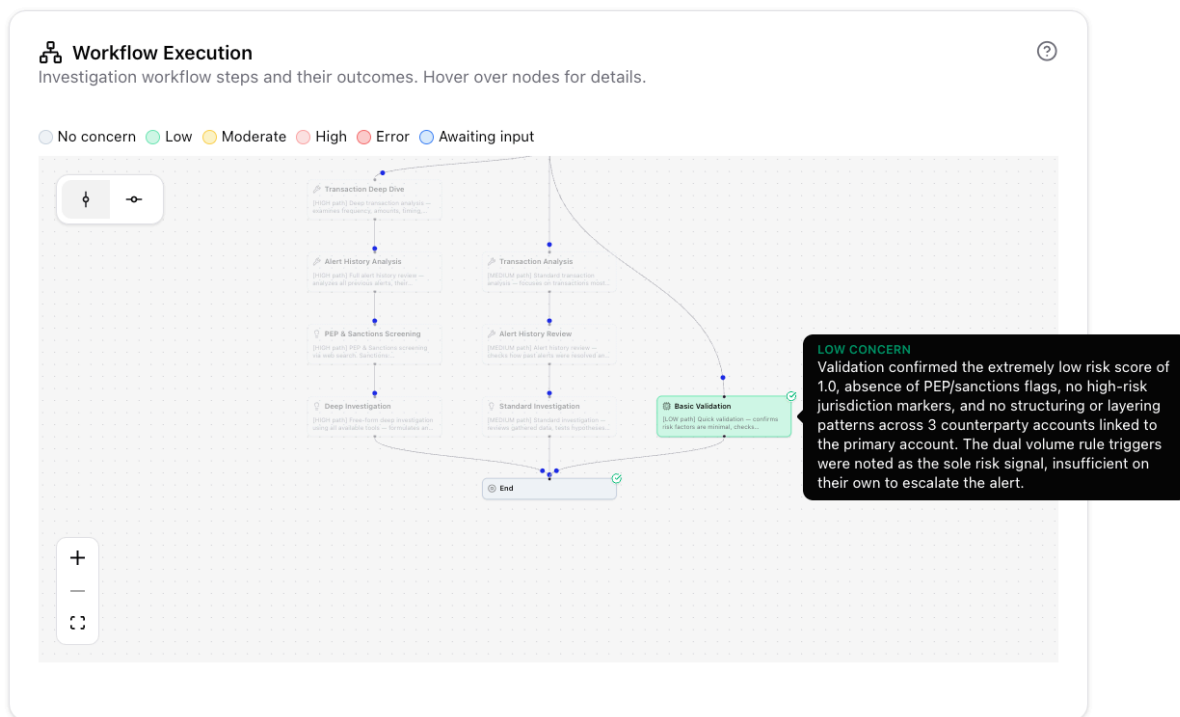
新 workflow、提示和模型版本不应全局启用。采用“领先者/挑战者”方法，在相同案例上，将所提议的变更（挑战者）与现有方案（领先者）进行对比，并在推广前比较结果。这通过影子运行或并行运行、试点到生产路径以及在黄金数据集上进行回测来加强，每个阶段都有明确的审批关卡。其结果是可控、可逆的发布，其中变更可以根据证据进行推广或回滚，而不会造成中断。

6.8 持续确保证书，而非一次性批准

综合来看，这些实践将验证从一次性的批准事件转变为持续的保证。相对于经典的模型验证，有两个元素是真正新颖的——对抗性/红队测试和运行时行为监控——它们都直接源于智能体会行动、读取不可信输入并以非确定性方式行事这一事实。经典的检测人工智能的可解释性原则得以延续，但它们已从解释单个决策扩展到解释整个调查链。

图4：代理 workflow 审计追踪（白盒可解释性）

一个完成的调查视图，显示 workflow 路径、每步状态、参考的数据来源、应用的决策标准/风险因素、置信度指示、引用/思维链，以及人类+AI联合的审计追踪；包含一个用于单步的带结构化验证叙述的悬停/详情面板。

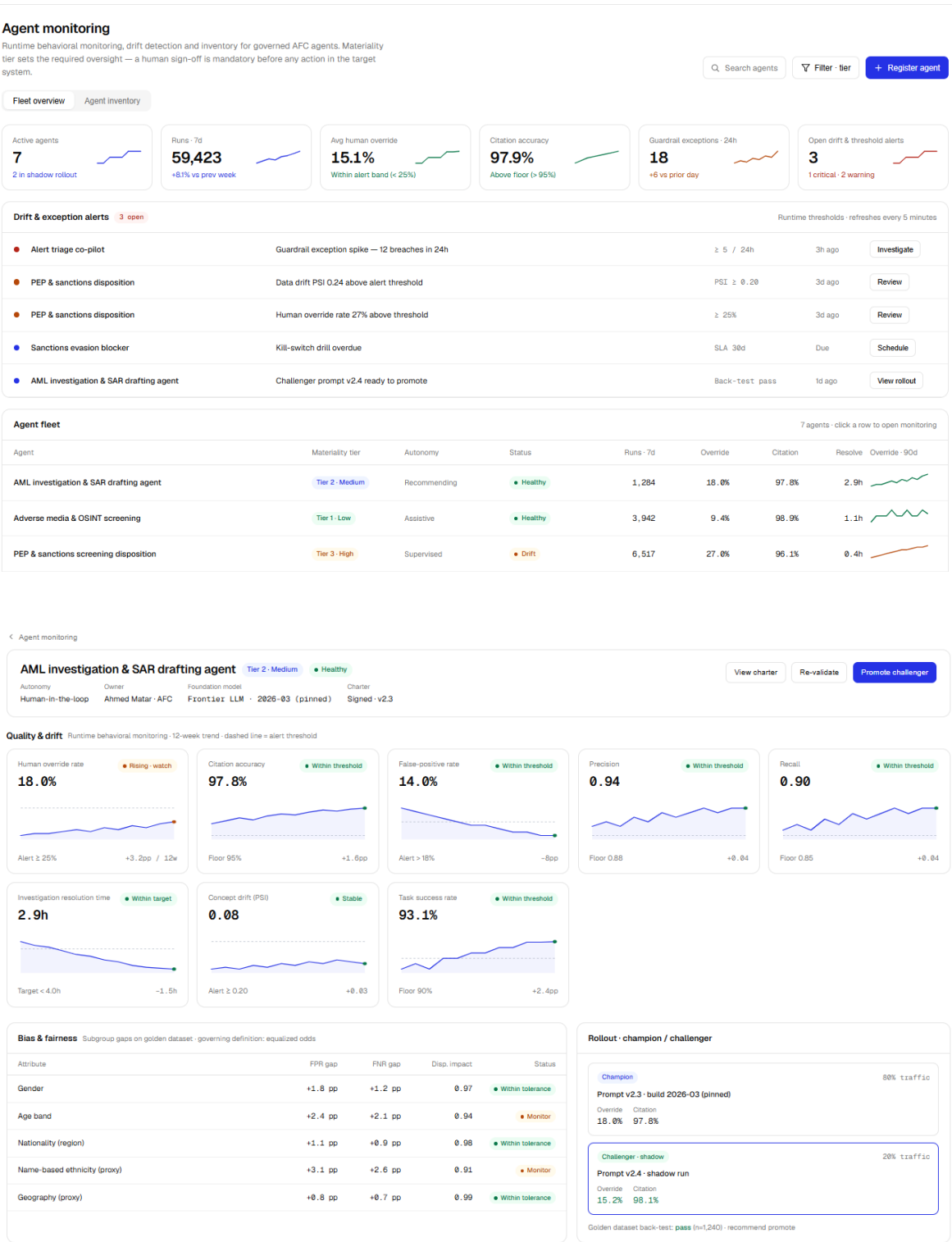


Source: Hawk.

对于自主型AFC系统，其验证不仅限于部署前测试。机构需要证据，证明在整个智能体生命周期中，决策、工具使用、数据来源和人为干预均可被追踪、审查和质疑。

图5：监控与漂移看板

一个监控面板概念，展示指标集（6. 6：精确率/召回率、FPR、告警至SAR比率、覆盖率、引用准确率、数据/概念漂移、解决时间）及其阈值和告警状态。



Agent monitoring

Runtime behavioral monitoring, drift detection and inventory for governed AFC agents. Materiality tier sets the required oversight — a human sign-off is mandatory before any action in the target system.

Q Search agents

▼ Filter: tier

+ Register agent

Fleet overview

Agent inventory

Agent & workflow inventory									
Components, versions, permissions & change history - configs and prompts are versioned artifacts									
Agent	Tier	Autonomy	Foundation model	Tools & scope		Data	Prompt	Owner	Last change
AML investigation & SAR drafting agent	Tier 2 - Medium	Recommending	Frontier LLM - 2026-03	5 read	1 write	7	v2.3	Ahmed Matar - AFC	Jun 28
Change history									
Components & versions									
Tool permissions - least privilege									
Foundation model	Frontier LLM - 2026-03 (pinned)			case.read	kyc.read	txn.read	sar.draft.write	Jun 28	Challenger prompt v2.4 entered shadow rollout
System prompt	v2.3 - versioned			View monitoring		Open charter		Jun 28	Prompt v2.3 change reviewed
Retrieval / RAG index	kb-am1 - 2026-06							Jun 10	Retrieval index refreshed
Orchestration	Workflow - 6 tool nodes							May 22	Model build 2026-03 pinned
Adverse media & OSINT screening	Tier 1 - Low	Assistive	Frontier LLM - 2026-02	4 read	no write	4	v1.7	L. Bianchi - AFC	Jun 12
PEP & sanctions screening disposition	Tier 3 - High	Supervised	Frontier LLM - 2026-01	6 read	2 write	9	v3.1	M. Okafor - MRM	May 20
Sanctions evasion blocker	Tier 4 - Critical	Autonomous	Frontier LLM - 2025-12	3 read	3 write	5	v4.0	S. Nakamura - Tech	Jun 05
Alert triage co-pilot	Tier 2 - Medium	Recommending	Frontier LLM - 2026-03	4 read	1 write	6	v2.0	B. Perez - AFC	Jun 24
KYC refresh assistant	Tier 1 - Low	Assistive	Frontier LLM - 2026-02	3 read	1 write	3	v1.2	G. Pessina - Ops	Jul 01
Typology analysis agent	Tier 2 - Medium	Recommending	Frontier LLM - 2026-03	4 read	no write	5	v1.5	L. Bianchi - AFC	Jun 19

Source: Hawk.

持续的监控应将模型、数据、运营和业务风险信号与明确的阈值和升级措施联系起来。这使得验证从一次性批准转变为在代理运行和演进过程中的持续保证。

7. 治理、控制及权限

现有的监管指南始终强调人工智能系统需要清晰的治理架构、明确的问责机制、独立的质疑环节、资产清单以及文档记录。以OCC框架为例，这些治理原则通过类比仍适用于代理式AFC系统，但已超越底层模型，扩展至更广泛的代理式工作流程。政策与治理框架覆盖整个工作流程；角色、职责与问责机制超越底层模型，涵盖更广泛的代理式系统，并且独立的质疑环节适用于代理式工作流程，而不仅限于嵌入式模型。

角色、职责和人机协同决策权限必须明确：谁有权授权哪些代理行为，以及在何种重要性级别下授权。对于调查反洗钱（AML）用例，应确保合格人员批准目标系统中任何具有后果的行动。其他允许有限自主行为的AFC用例应被视为关键级系统，并需接受最严格的授权、监控、隔离和干预控制。

自主系统同样引发了身份和权限的问题，而经典模型则从未涉及这些问题。一个自主体应始终持有其自身的非人类身份。当它代表某人行动时，应使用委托的、代表他人行使的权限（授权而非伪装）；当它处于会话之外运行时，应使用其自身的、有期限的、范围受限的凭证（客户端凭证/工作负载身份）。在所有情况下，其可触及的范围都受限于自主体的章程，因此权限和预期用途保持一致。

现有的模型库存实践可以自然地扩展到代理/工作流库存，该库存捕获每个代理的组件、版本、权限和变更历史，并将配置和提示视为可版本控制的、有文档记录的工作件，而非非正式设置。文档记录和审计追踪将保持可供审计的状态，以支持独立挑战、内部治理和监管审查。

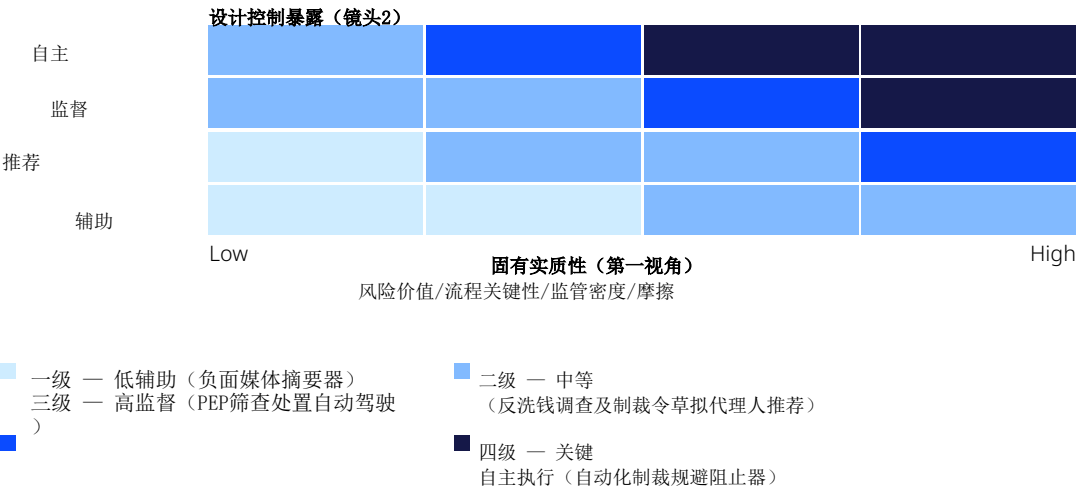
治理也必须通过企业代理保证层进行扩展，该层位于任何个人AFC用例之上。企业人工智能或技术应提供通用注册、评估、追溯存储、监控和发布控制，而AFC拥有代理宪章、域策略、测试、指标、阈值和人类决策权。上述控制对少数代理是可行的，但机构很快将运行数百个代理，可能无法从头开始验证每个代理或全面审查其活动。这不会改变上述特定层级的决策权；它要求周边的保证流程进行扩展。当许多代理共享共同能力时，该能力只需验证一次，并重用证据，而新增的审查则专注于增量风险，同时基于信号的监控会暴露偏差，而不是将注意力均匀分散到每个代理。

最后，治理负责在前一章中引入的跨职能控制：公平性结果及其监控、稳健性/数据中毒测试的日程安排和所有权，以及事件机制——检测、遏制、回滚和披露——并明确界定跨AFC、MRM、技术、法律、审计和供应商利益相关者的升级路径。

表4：按重要性层级划分的决策权梯级

物质性 tier	代理 自主权	所需人力 批准	独立挑战 以及监督
Low	辅助—草稿和 总结；人类 作者的决定	人类决定 一切	标准问答采样
中等	推荐 — 提出 一种有道理的性质	人工审核和 批准每个输出	定期审查；双人复核 样本
High	受控行动——作用于 日常案件，人类 在循环中	人类批准 例外；能够 干预或覆盖	实时监控；全面审计 小径；辅以定期的 独立验证和 定向审查
关键	章程内的自主权 —行为升级 仅例外	预先授权于 界限；强制性的 异常升级	持续保证， 独立挑战， 击杀 切换

图6：治理运营模式与决策权阶梯



欧文咨询和霍肯分析。

8. 供应商和第三方代理解决方案：无需转移责任的责任保障

各机构在构建、采购或整合代理型AFC系统组件方面将有所不同。内部开发可能提供更大的控制力、定制化能力，并能更紧密地与机构特定的数据、工作流程和治理要求保持一致，而第三方解决方案则可能提供更广泛的类型、数据环境、部署模式、代币成本优化和监管预期方面积累的经验。外部供应商也可能提供特定领域的 workflows、预构建的集成、专业知识和经过验证的控制措施，从而可以加速实施和保障。

然而，第三方采购并不能转移治理责任。虽然一个有能力的供应商可以通过提供成熟的测试工具、标准化的证据和可重用的控制组件来减轻机构的保证负担，但内部开发可能提供更直接的系统行为、配置和证据的访问途径。在任一模式下，验证、持续监控、结果分析以及干预的能力仍然是机构的责任。⁵配置好的代理必须根据机构自身的政策、数据、权限、流程和风险偏好进行评估。供应商通过提供机构进行高效评估所需的配置透明度、测试工具和标准化证据来支持这一点。

承担义务的主体必须能够验证配置的代理，在生产环境中监控它，评估供应商和模型变更，调查故障，重新验证材料更新，并应对独立或监督性的挑战。这些义务的适用性与系统是自行构建还是购买无关。采购方式决定了该机构履行这些义务的能力如何。当供应商提供提示、组件版本、工具路径行为、运行时跟踪、故障记录和变更历史——并附带与之协作的工具——这可以加速机构的保证活动，并支持更一致的证据。

第5号运营手册2026-13a，第七节（供应商及其他第三方产品）：即使组件是专有的，供应商模式风险管理原则仍然适用。

技术可以外部采购；保证结果仍是机构的责任。供应商可以提供企业代理保证层的大量组件——越来越像是一种产品化能力而非定制化让步——但机构必须保留对管理已部署系统所需的证据和干预权的直接或合同强制执行访问权限。技术可以外部采购，而保证结果仍是机构的责任。

因此，确保访问权限应被视为既是采购标准，也是部署门槛。在批准第三方代理之前，机构应确定其能否配置代理以符合自身政策；在机构特定的代表性、边缘性和对抗性案例上对其进行测试；重建并导出其执行轨迹；识别当前生效的模型、工具、提示和配置；接收重大变更的通知；进行独立挑战；使用自身阈值监控结果；并在必要时暂停、限制或回滚代理。如果提供方展示了并合同上支持这些能力，评估可以侧重于确认并记录其针对特定部署的充分性；否则，可能需要额外的权利或补偿性控制。

这些要求是结果导向的。根据重要性，可以通过架构文档、版本清单、受控测试、可追溯导出、独立保证报告、合同审计权以及联合监控来提供充分保证。

表5：第三方代理系统的最低保障访问权限

保障能力 最低要求	
客户可配置性	机构可以定义或批准章程、政策、工具权限、数据访问。 自主程度、升级逻辑和人工审批点
Institution-specific 可检验性	一个沙盒、测试租户或等效机制支持黄金数据集、回归测试。 边缘情况，以及使用代表性机构场景进行对抗性测试
运行时可观测性	运行级别证据涵盖 workflow 步骤、模型和工具交互、源数据血缘关系 行使的权限、错误、人工干预以及生效的版本
证据便携性	痕迹、检测结果、监控数据和相关记录可以被导出到 该机构的自身证据、风险或档案保存环境
改变管理	该机构收到关于实质性模型、提示、编排、工具或 控制变更，并且可以在部署前或部署后立即进行回归测试
独立挑战	该机构及其独立的控制功能可以测试结果、审查相关 控制证据，获取访问失败信息，并质疑供应商的结论
干预并退出	该机构可以暂停服务、撤销代理权限、降低自主性、回滚 调整背景材料，保留历史证据，并有序撤离
数据和安全控件	租户隔离、数据驻留、子处理器透明度、保留控制以及 使用客户数据进行基础模型训练的禁令已有记载。 并且可执行

要求应与材料性相匹配。机构与供应商应在初期就商定拟议层级所需的证据和干预权，并确认平台能提供这些内容。若某项能力尚不存在，可行的路径是制定联合路线图：最初在较低自主权层级部署，在平台周围添加独立控制，或缩小范围直至该能力可用。如果这些措施未能提供与拟议层级相称的保证，机构就不应在该层级部署。

通用保证标准或平台级认证最终可通过证实组件清单、追溯模式、评估方法、变更通知、安全控制和审计员访问的基本标准来减少重复评估。它们不会取代针对特定机构的配置代理的验证。

第三方采购可以加速部署，但这并不转移责任。机构应保留管理代理人所需的相关证据、访问权限、干预权利和独立保证，以确保根据其重要性对其进行管理。

9. 示例：反洗钱调查代理

为使框架具体化，可考虑一个AML调查代理，该代理负责对一级警报进行研究和草拟。它不监控实时交易流；一旦该机构的主要检测系统发出警报，该代理就会在机构配置的工作流程中对该特定警报进行深入调查。

附件7：受监管的AML调查工作流程的示例实施

使用合成数据进行鹰式示例。顶部：针对人类（HITL）的警报摘要、评估和行动建议。中部：遵循FI标准操作程序（SOP）的代理工作流程路径审计追踪。底部：类型评估和潜在风险评估。

 **Investigation Summary** 95%

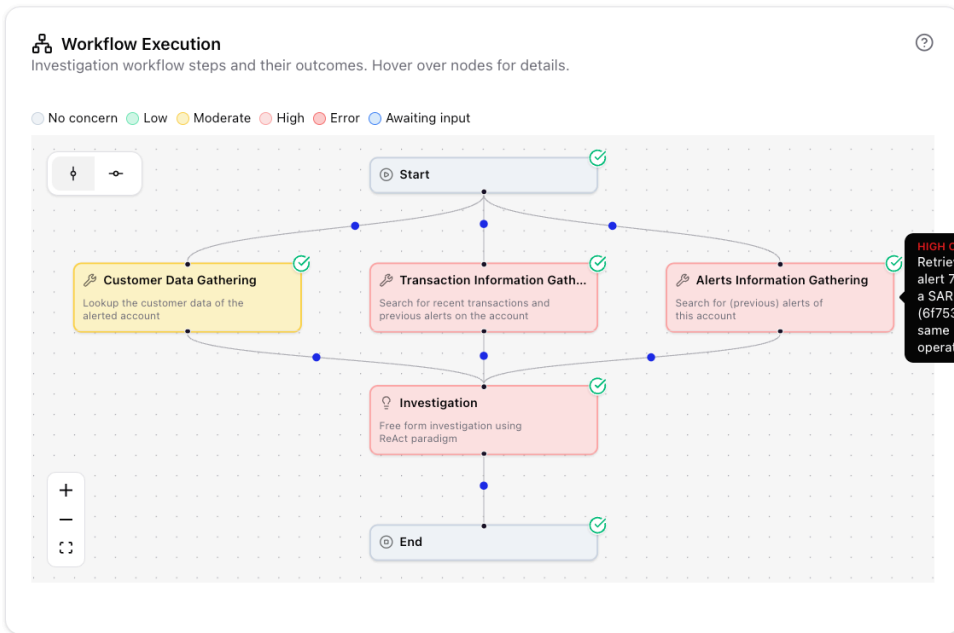
AI-Generated Analysis and Recommendation

 **Escalation Recommended**
This alert requires escalation due to identified risk indicators. Please follow organizational protocols for handling high-risk alerts.

Overview
Auto Refactory Co. received **€18,000 across 6 overnight transactions** from its own majority shareholder Bernhard Heils, who used **multiple accounts and name variants** — a pattern consistent with **structuring (smurfing)** and **multiple identity / account obfuscation**.

Outcome
Escalation is warranted: a **SAR was previously filed** confirming prior investigator agreement, and a **classic structuring pattern** combined with a **self-dealing counterparty** leaves no credible benign explanation. Next steps should include **obtaining a source of funds explanation from Bernhard Heils**, **identifying all five source accounts** used in the transactions, and **reviewing the prior SAR filing and linking findings to the open related alert**.

受监管的代理机构可在保持人类问责制的同时加速反洗钱调查。其章程、风险等级、权限边界、验证证据和升级路径必须确定其可执行的操作，以及人类批准仍然必需的环节。



Detected Typologies
Known patterns identified during the investigation

Structuring (Smurfing)	95%	▼
Self-Dealing / Insider Layering	82%	▼
Unusual Transaction Timing / Operational Anomaly	78%	▼
Multiple Identity / Account Obfuscation	80%	▼
Cross-Border Opacity / Jurisdiction Mismatch	55%	▼
SAR Evasion / Repeat Suspicious Activity	72%	▼

Q

Key Findings

Evidence and insights surfaced by the investigation

6

Risk

2

Mitigating

€18,000 structured across 6 overnight transactions

Risk

98%

▼

Counterparty is majority shareholder using multiple accounts

Risk

97%

^

All 6 transactions originate from Bernhard Heils (60% owner of Auto Refactory Co.)

Three name variants used: Bernhard Heils / Bern Heils / B. Heils

Five distinct source account numbers used across the cluster

Self-dealing pattern: shareholder sending funds to own company via fragmented transfers

Related Typologies (4)

Structuring (Smurfing)

Self-Dealing / Insider Layering

Multiple Identity / Account Obfuscation

Cross-Border Opacity / Jurisdiction Mismatch

Sources (38)

Case 7fc05b8f-2712-4366-8539-4612d3f25f09

Case 6f753f24-e3a6-426f-80be-69fb121f735a

Case 3219aa70-0876-4c48-8295-d50cc554e9b8

Case 5003ab96-16bd-4ad7-bbb3-562b0e3687ce

Case 24466c86-e81e-4095-8b3e-20a1baf56759

Case a9e9375d-e77d-42b3-9d26-5ad47031cfcf

Case 225f48f1-9cf8-49e5-a4a0-8bef587a443c

Case 9511100c-76c5-4bb7-8f75-d7e67daa4ee2

Case 1906a229-7607-4ba5-ad15-5dab343fac20

Case a881413e-923f-4106-ba44-24540d2fa78d

Source: Hawk.

授权与重要性。 代理人的授权仅限于调查和草拟：整合内部和外部数据、总结案例背景、识别相关类型、建议后续步骤、并准备SAR叙述草稿——始终保留审计追踪，且绝不冻结账户、终止客户关系或向金融情报单位报告。在第四章的重要性矩阵中，此项属于中高重要性，因为其输出结果将用于监管决策，但它未达到最高级别，正是因为其无法采取行动。这一分类决定了控制集的设置。在中高重要性级别下，它会调用决策权等级第七章的建议层级——要求对每项处置进行人工强制审批、对样本进行独立挑战，并对推理链进行完整运行时监控和记录——而不是仅保留给被授权采取行动的代理人使用的实时监督、仅限异常的升级和强制停止功能。一旦机构允许代理在目标系统中采取任何行动，所需的治理层级将提升至最高级别，并引入最全面的控制集。

验证、检查点、监控和证据。 在部署前，代理程序会在典型案例和对抗性案例上进行端到端测试；任何处置决定前都必须进行人工介入检查点；运行时监控会追踪第6章设定的指标；并且每个发现都由可解释性要素支撑——路径、来源、标准、置信度和引用。这是一个具体的工作流程：首先触发结构化警报，代理程序并行收集KYC信息和交易历史，构建时间线，筛选负面媒体，识别候选类型，并生成包含建议处置方案和初步叙述的结构化摘要。分析师随后对输出结果进行质询，接受或修正，并做出最终决定。

具体而言，供应商可以如此支持在第8章建立的保障能力：

保障能力	最低期望	供应商支持示例
客户可配置性	机构可以制定或批准章程。策略、工具权限、数据访问、自主制定策略和标准操作程序，并将其整合为能动型工作流程级别、升级逻辑、以及人工审批点，并独立配置每个节点——工具，	工作流管理器：该机构将其数据来源，自主性，升级逻辑以及人类审批点。工作流是按领域分类（反洗钱、欺诈、筛查、）SAR叙述）并与独立的提示和案例-动作语义。类型学管理层允许该机构进行策展、版本控制。并为其自身类型分类以依附于个体工作流步骤
Institution-specific 可检验性	沙盒、测试租户或等效机制 支持 golden-dataset、回归、边缘案例 并且使用有代表性的对抗性测试 制度场景	机构专用沙盒租户 专项测试，并与历史数据回溯 该机构自身的黄金数据集——正在运行 机构自行服务或联合服务 供应商
运行时可观察性	运行级别证据涵盖工作流步骤、模型，每次调查均按运行记录。 以及工具交互、来源追溯、权限 工作流运行视图 — 执行的工作流步骤 已执行、错误、人工干预以及所调用的工具和数据源、模型输出 生效版本	类型匹配，以及分析师干预 在流程版本生效的情况下。代理式 绩效衡量增加了定量的 决策质量报告，基准测试 代理人的决策与分析师的结果相悖， 文档政策
证据可移植性	痕迹、检测结果、监控数据以及相关的运行记录、决策依据和案例审计 记录可导出到机构的自有轨迹中，按租户保留，并可访问。 证据、风险或记录保存环境制度以供其出口自己的证据	记录保存环境
变革管理	该机构收到适当的通知 材料模型、提示、编排、工具，或 控制更改并可以执行回归 部署前或部署后立即进行测试	材料平台的变更已传达 通过发布说明，该机构可以在它的沙盒中对其代理进行回归测试 在领养之前。工作流程和类型 版本已置顶：一个更新版本 以通知形式出现，并并排显示 仅在明确制度中采用差异。 批准——从不默默进行。
独立挑战	该机构及其独立控制 功能可以测试结果，审阅相关 控制证据，获取访问失败信息 并质疑供应商的结论	沙盒测试代表性变更 回溯
干预与退出	该机构可以暂停服务，撤销 代理权限，降低自主性，回滚 实质性变更，保留历史证据 并执行有序退出	完全自助控制：该机构可以 激活、暂停或停用代理，修改 或撤销工作流步骤和工具权限 减少自主权，禁用连接器 来源，并更改运行计划——而没有 供应商参与。历史运行证据 当代理被暂停时，会保留。 工作流已停用。
数据和安全控制	租户隔离，数据驻留，子处理器 严格租户隔离，并有文档记录的租户 透明度、保留控制及禁止架构；数据驻留、分包商 使用客户数据来训练基础模型 模型已文档化且可执行	并且留存期限已记录在案。 合同约定。客户数据并非 用于训练或改进基础模型。

10. 从框架到制度实践

机构不太可能一步到位达到目标状态。一个务实的实施路径始于建立可见性、所有权和边界明确的权限；然后标准化可重用的控制措施和证据；最终将保证和执行嵌入到机构的技术平台中。

第一阶段：建立可见性、所有权和边界

- 库存代理活动：识别已在使用或处于试点阶段的AFC代理和类似代理的工作流程，指派负责的负责人，并使用第四章框架对每个进行分类。
- 定义允许的操作边界：为每个代理建立一份章程，涵盖其目标、范围、授权权限、禁止行为、数据与工具访问权限，以及所需的人为决策和升级节点。
- 明确治理主页：更新模型和非模型治理边界，以便在AFC、MRM或AI风险、技术、网络、数据、隐私、法律、审计和第三方风险方面，使能动式工作流具有明确的生命周期、审批路径和所有权模型。

第二阶段：标准化可重用控件和证据

- 开发可复用的代理原型和控制模式：为常见的重复使用场景定义通用设计，并辅以相称的审批要求、人工监督模型、授权模式、评估标准及证据预期。
- 建立通用的验证和证据标准：要求端到端测试、证据溯源、执行追踪、变更记录、监控阈值和再验证触发器，并在适当情况下重用适用于通用能力的基线保证证据，同时每个配置的代理仍需接受端到端、机构特定的验证。
- 制定采购要求：要求第三方解决方案支持机构特定测试、追溯与证据导出、配置透明、物料变更通知、独立挑战、干预权以及有序退出。

第三阶段：将保障嵌入平台

- 实施企业代理保障层：将通用注册、身份识别、策略执行、测试、发布控制、追踪、监控、暂停和证据保留等功能应用于机构的AI工厂、代理平台和第三方解决方案。
- 迈向持续保证：尽可能自动化控制检查和发布关卡，监控运行时行为和结果，并将异常连接到事件管理、独立挑战和定期治理审查。

这种排序不应被理解为严格线性。机构可以并行发展不同的能力，但进程很重要：可见性和权威提供了控制基础；标准化使治理可扩展；平台层面的执行使其可持续。

11. 结论

金融机构无需等待专门的代理式人工智能监管，即可在金融科技领域部署代理式系统。现有的监管指南和行业框架已提供可类推适用的有用原则，尽管它们并未为代理式人工智能建立一套完整的治理标准。挑战并非要取代这些原则，而是要将它们从治理单个模型扩展到治理更广泛的代理式系统——包括其编排、工具、数据访问、授权委托、人工监督和审计追踪。无论是内部构建还是向第三方采购，每个实质性代理都应连接到企业代理保障层，以便机构能够对其进行测试、观察、质疑、约束和停止。

这一更广泛的视角的一个重要启示是，设计选择可以在不影响用例固有重要性的前提下，实质性影响残余风险和部署条件。虽然用例的固有重要性无法改变，但可以通过围绕自主性、工具权限、工作流约束、护栏和人工监督等方面的工程选择来有意塑造代理系统的残余风险。因此，治理不仅是一门合规学科，也是一门架构学科。

最终，治理问题已从“每个模型组件是否适用？”扩展到“AI支持的调查行为是否具有边界、基于证据、可审计、可质疑、可监控、可解释，并与机构的AFC风险画像保持一致？”能够用证据回答第二个问题的机构，将更有信心地采用自主AFC。

附录A——主要参考文献

- 美国货币监理署公告2026-13及跨机构《模型风险管理监督指南》（美国货币监理署2026-13a），美国货币监理署/美联储/联邦存款保险公司，2026年4月17日。
- 沃尔夫斯贝格集团，《在金融犯罪合规中使用人工智能和机器学习的原则》，2022年12月。
- 金融行动特别工作组，《前瞻扫描：人工智能与深度伪造》，2025年12月22日。
- 美国国会，《反洗钱法2020》，公共法第116-283第F部分，2021年1月1日。

免责声明

奥利弗·怀特曼 (Oliver Wyman) 对于本报告或任何基于本报告所载结果、建议或意见所采取的行动或做出的决定，不对任何第三方承担任何责任。

本报告不构成法律建议，法律建议只能由律师提供，您应当寻求律师的建议。此处所表达的观点仅适用于本报告所述目的，并自本报告日期起有效。本报告全部或部分内容所依据的由他人提供的信息，据信是可靠的，但未经核实。对此类信息的准确性不作任何保证。公开信息、行业和统计数据来源于 Oliver Wyman 认为可靠的来源；然而，Oliver Wyman 对此类信息的准确性和完整性不作任何陈述，且已在不作进一步核实的情况下接受了此类信息。对于市场状况或法律法规的变化不承担责任，亦不承担修订本报告以反映自本报告日期起发生的变化、事件或状况的义务。

威灵顿咨询公司（Oliver Wyman）， Marsh（纽约证券交易所代码：MRSH）旗下的企业，是一家以深刻行业洞察、大胆创新及协作方式见长、能够化繁为简、助力组织应对其最具定义性的转型时刻的管理咨询公司。Marsh是全球在风险、再保险与资本、人力资源与投资以及管理咨询领域的领导者，为130个国家的客户提供建议。公司年营收达270亿美元，拥有超过9.5万名同事，致力于通过独特的视角帮助客户建立信心，从而蓬勃发展。

更多信息，请访问 oliverwyman.com，或在[领英 \(LinkedIn\)](#) 和[推特 \(X\)](#)上关注我们。

美洲 +1 212 541 8100	欧洲 +44 20 7333 8333	亚太地区 +65 6510 9700	印度、中东和非洲 +971 (0) 4 425 7000
-----------------------	------------------------	-----------------------	---------------------------------

作者

斯特凡诺·博埃齐奥	大卫·蔡	沃尔夫冈·伯纳
伙伴，奥利弗·怀曼	伙伴，奥利弗·怀曼	联合创始人兼首席产品官 鹰眼人工智能

费利克斯·贝克汉博士	罗伯特·施穆克博士
首席人工智能官，鹰智科技	产品副总裁——反洗钱，鹰眼人工智能

版权所有。未经 Oliver Wyman 书面许可，本报告不得全部或部分复制或转载。

在此方面，奥利弗·怀曼对第三方行为概不负责。

本报告中的信息与观点由 Oliver Wyman 整理。本报告不构成投资建议，亦不应被视为投资建议或替代专业会计师、税务、法律或财务顾问的咨询。Oliver Wyman 已尽一切努力使用可靠、最新且全面的信息与分析，但所有信息均未经保证，无论明示或暗示。Oliver Wyman 不承担更新本报告中信息或结论的责任。对于因依据本报告或本报告中引用的任何报告或信息来源所采取或未采取的任何行动而导致的任何损失，或因任何后果性、特殊或类似损害（即使已被告知此类损害的可能性），Oliver Wyman 不承担责任。本报告不构成买卖证券的要约或招揽买卖证券。未经 Oliver Wyman 书面同意，本报告不得出售。